8章
データガバナンスとデータセキュリティ

この章では、データガバナンスとデータセキュリティに焦点を当てます。なぜこれらのテーマを一緒に議論するのでしょうか。それは、両者が重なり合うものであり、共通の目標を持つものだからです。データガバナンスは、データが何を表し、何に使用できるかを決めるものです。そして、データセキュリティは、許可された関係者だけが（使用目的に沿って）データにアクセスできるようにするものです。

アーキテクチャのすべての領域に対して、セキュリティを統一的に適用するには、標準化とメタデータ管理が必要です。データオーナーを割り当て、分類を設定し、関係者間の契約を管理する必要があります。これらの情報はすべて、統一されたモデルで一元的に保管されるべきです。この章ではこれらの多くの問題を取り上げ、残りの問題は9章で取り上げます。

8.1　データガバナンス

なぜ、データガバナンスが必要なのかと疑問に思われるかもしれません。データガバナンスは制約が多く、お役所的で、支配的なプロセスだと思われがちです。データガバナンスは、データに対する取り組みを遅らせてしまうのではないかと思われることでしょう。これらの疑問はもっともです。実際、小規模の企業やベンチャー企業では、正式なデータガバナンスが存在しません。日々の活動の中で暗黙のうちに行われているためです。小規模な組織では、ほとんどのアプリケーションとデータは少数の人によって所有・管理されています。データの量や種類は比較的限られているため、必要なデータを見つけ、質問に対する回答を得るのにほとんど時間がかかりません。多くの場合、隣の席の同僚に質問するだけで良く、その同僚が答えを知らなくても、数席先のデスクで答えが得られるでしょう。

企業が成長し始めると、問題が発生します。部門間の移動時間は増え、より多くの人が異なる視点で考え、情報がばらばらになり、意思決定に時間がかかり、責任範囲が曖昧になり、データ品質の問題が改善されなくなります。データの消費量や使用量が増えれば増えるほど、組織化、説明責任、透明性の確保が急務となります。さらに、企業は、欧州の一般データ保護規則（GDPR、General Data Protection Regulation）や、カリフォルニア州消費者プライバシー法（CCPA、California Consumer Privacy Act）など、新たな法規制に直面しています。これらの法規制では、データ利用の完全なコントロール、データ流通方法や場所の把握や、責任範囲の明確化などが求められています。また、これらの法律では、データがどこに保存され、どこから来たのか、何のために使われているのか、どのように使われているのか、誰が管理しているのかを特定し、明確にドキュメント化することが求められます。何千ものアプリケーションやデータベースを運用しながら、コンプライアンスを確保することは、非常に難しい課題です。このように、データガバナンスの必要性は明らかです。

しかし、データガバナンスの問題点は、ほとんどのプログラムとプロセスがまったく効率的ではないことです。データガバナンスソリューションは、多くの場合、大量の複雑なポリシーとガイダンスで構成されており、データを利用することよりも、むしろコントロールすることに重点を置いています。このようなポリシーが導入されると、データが「ガバナンスされる」、または「管理下に置かれる」まで、誰もデータを見たり使用したりすることができません。

多くの組織は、複雑なツールを使ってデータガバナンスを実現しようとします。これらのツールは設定が複雑で、ほかのソリューションとの統合が難しい場合があります。さらに、ルールベースのワークフローと監査証跡を導入し、必要なドキュメントをアップロードするには、長いプロセスが必要です。また、データガバナンスに対する関心は低く、その価値が理解されていない場合も少なくありません。では、このような課題を理解した上で、データガバナンスをより実用的で効果的なものにするためには、どのように工夫をすればよいのでしょうか。これから説明していきます。

8.1.1　ガバナンスフレームワーク

効率的なデータガバナンスを構築するには、組織文化、設計、運用モデル、役割の見直しから始めます。これまではデータドメインのような抽象的な概念を使ってきましたが、これからはデータの可用性、有用性、完全性、セキュリテ

ィを確保するために、具体的な役割と責任、ポリシーと標準、作業指示など、より具体的な枠組みを定義していきます。まず役割から説明します。

8.1.1.1　役割

データガバナンスはそれぞれの組織に固有のものであることを理解しておく必要があります。データガバナンスは、それぞれの組織固有のニーズに合わせて構築する必要があるからです。したがって、データガバナンスのフレームワーク全体において、主要な活動は名前も内容も企業によって異なります。また、組織によって、これらの役割の構成や呼称は少しずつ異なります。とはいえ、ここではデータガバナンスにおける一般的な役割と責任を大まかに説明します。

最高データ責任者（Chief data officer）
最高データ責任者は、データ戦略全体とデータ管理業務の責任者です。この責任者は、ビジョン、方向性、標準を策定します。この役割は、**データガバナンスリーダー**や**データ管理責任者**と呼ばれることもあります。

データオーナー
データオーナーは、**データ受託者**や**プロセスオーナー**と呼ばれることもあります。データオーナーは、対象となるデータと、そのデータに対応するメタデータを適切に管理する責任を負います。データ品質、データ定義、データ分類、データの使用目的、ラベルなどを管理します。分散型エコシステムにおける説明責任は、エンタープライズデータだけに限定されるものではありません。データオーナーは時にはプロダクトオーナーでもあるため、チーム内の優先順位やバックログを管理する責任もあります。

ビジネスユーザー
ビジネスユーザーとは、高レベルの意思決定者であり、一般的にはプロダクトオーナーやビジネス担当者であり、要件に関してビジネスチームと共同で作業を行います。また、データ管理ポリシー、プロセス、要件に関してガバナンスチームと共同作業します。ビジネスユーザーは、ビジネス要件を高レベルのソリューションに翻訳する戦略家の役割も果たします。

アプリケーションオーナー
アプリケーションオーナーは、**データ管理者**と呼ばれることもあります。アプリケーションオーナーは、アプリケーションのコアとそのインタフェースを管理します。アプリケーションオーナーは、ビジネスの提供、機能、サービスとともに、アプリケーション情報とアクセス制御の管理に責任を負います。

データユーザー
データユーザーは、特定の目的のためにデータを使用することを意図し、要件を設定する責任を負います。

データ作成者

データ作成者は、アプリケーションオーナーとデータオーナーとの合意に基づいてデータを作成する内部パーティまたは外部パーティのことです。

データスチュワード

データスチュワードは、データポリシーとデータ標準が遵守されていることをチェックします。データスチュワードは、特定のデータの専門家である場合が多いです。

データガバナンスの役割を定義することは、データガバナンスプログラムに不可欠です。そして、役割に応じてオーナーシップを割り当てることが必須です。これにより、全員の責任が明確になり、最善の成果が得られます。

これらの役割を検討するとき、なぜデータオーナーとアプリケーションオーナーの両方が存在するのか、不思議に思うかもしれません。なぜオーナーは1人ではないのでしょうか。これらの役割を分離し、（データメッシュ理論に見られるように）1つの複合的な役割としないことには、多くの理由があります。まず、アプリケーションはさまざまなドメインで共有されるかもしれません。2章で、共有ビジネスケイパビリティについても学びました。共有ビジネスケイパビリティは、一般的に、as-a-serviceモデルを使用して一元的に導入され、組織のさまざまな部署に提供されます。この場合、オーナーシップに関する作業を異なる担当者が行う必要があるため、オーナーシップをきめ細かく設定しなければなりません。また、データ品質の是正や監督の責任者は、データパイプラインの構築担当者ではないことがよくあります。この2つは専門分野が異なります。一般的に、データを所有するにはビジネスコンテキストを深く理解する必要があり、アプリケーションを所有するには技術的なエンジニアリングのスキルが必要です。

8.1.1.2　フレームワークの作成

大企業では、前節で取り上げた役割はたいてい連合型で運営されています。それぞれのドメインには、正式なデータオーナーと、それをサポートするアプリケーションオーナーやデータスチュワードなどの役割があります。これらの役割を導入し、データを民主化し、責任を連合化させるプロセスは、企業にとって大規模な組織の変更を必要とします。この変革を支援するために、すべての役割を正式な仕組みとして組織に組み込むことをお勧めします。ここで仕組みとは、すべてのデータガバナンス活動の基盤となるフレームワークのことです。このフレームワークは定期的に見直し、更新する必要があり、先に説明した役割と整合させる必要があります。

もちろん、前述したように、フレームワークには役割以外のものも含まれます。責任、標準、手続きを追加して、フレームワークを拡充する必要があります。図8-1は、ドメイン指向の仕事の進め方の中で、さまざまなガバナンスの役割がどのようにグループ化され、どのように管理されるかを示したものです。連合型のデータドメインチームと中央データガバナンスチームが組み合わされています。それぞれの役割について、活動と責任のリストが示されています。

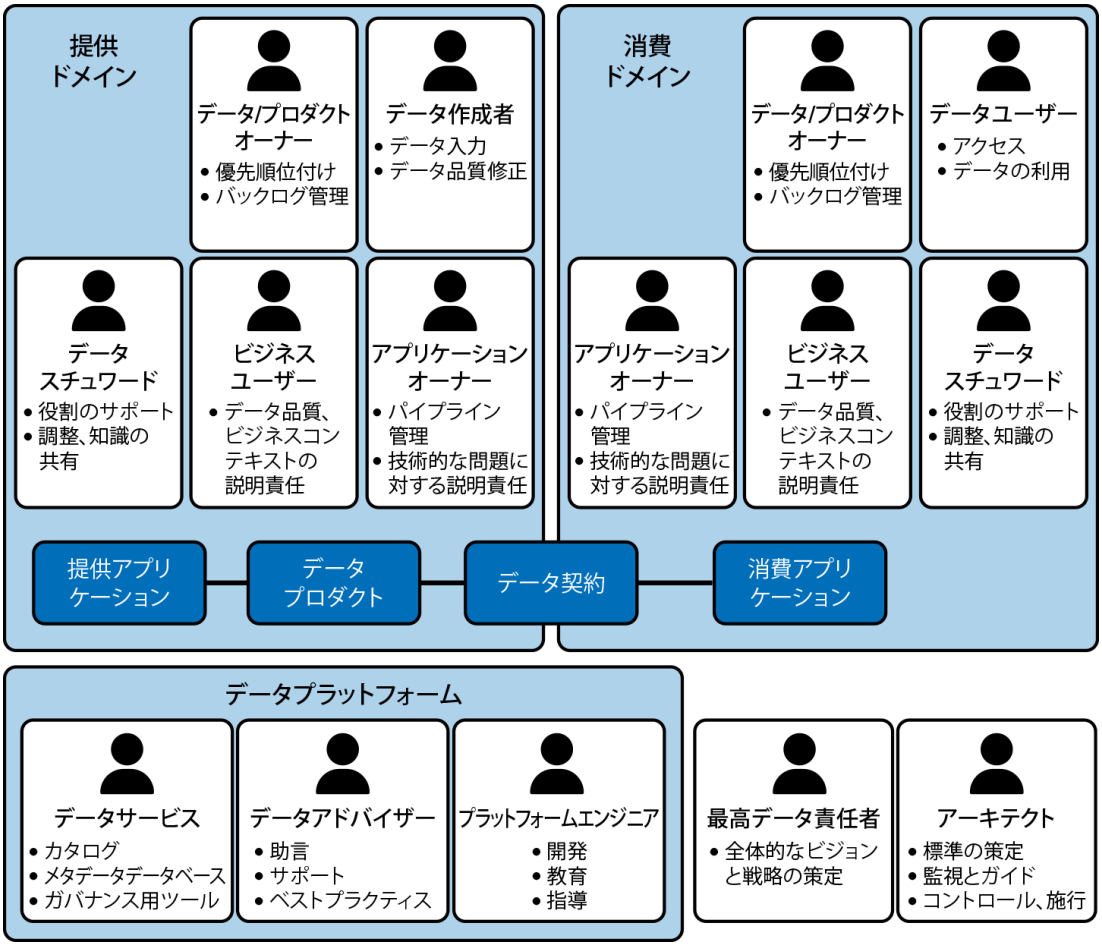

図8-1　高レベルのデータガバナンスフレームワーク。さまざまな役割を使用するドメインチームに組織を分割

図8-1の上部を見れば、この図がドメインに分割されていることがわかります。ドメインとは、ビジネスの特定の部分に焦点を当てた機能横断的なチームです。これらのドメイン内では、さまざまな役割がやり取りして、価値創造の目標を達成します。これらの活動では、データオーナー、アプリケーションオーナー、データ作成者、データスチュワードなど、さまざまなステークホルダーが協力し合います。

ドメインの下には、（中央）サービスを提供し、組織を指導する役割が描かれています。この部分では、アーキテクト、アドバイザー、エンジニアがプラッ

トフォームを開発し、相互運用性、メタデータ、セキュリティ、ドキュメント標準などの全体的なポリシーを定義します。

このガバナンスフレームワークで定義されたさまざまな役割は、単独では成り立ちません。多くの場合、緊密な連携が必要です。例えば、あるドメインのビジネスユーザーが別のドメインのデータオーナーにデータを要求するとします。そのデータがデータプロダクトとして一般公開されていない場合、データオーナーはそれが提供可能かどうかを判断する必要があります。もし提供可能であれば、対応するアプリケーションオーナーに連絡を取り、インタフェースの構築を開始し、データを利用可能にするプロセスを開始する必要があります。その後、そのデータがどのような目的で使用されるのかについて、さまざまなチームメンバーが理解する必要があります。そして、この合意事項はデータ契約書に記載されるべきです。

役割分担を明確にし、組織の全員が同じ見解を持つようにするため、すべての活動と責任について、フレームワークにも正式に規定することをお勧めします。例えば、フレームワークには、データ品質の要件や、データの監視、データの修正、その後の対応などの手順に関する詳細なマニュアルを記載してもよいでしょう。

フレームワーク自体をどのように構成すべきでしょうか。筆者はさまざまな組織と仕事をする中で、さまざまな構成を見てきました。例えば、フレームワークは、章立てされたWord文書（エグゼクティブサマリー、ガバナンス構造、役割の説明、データ品質、プライバシー管理、セキュリティ、コンプライアンスなどの手順）で記述することもできます。また、一連のWikiページにまとめ、データ作成と管理のライフサイクルにおけるさまざまな活動（データ品質の問題の検証と修正、データリネージの報告など）を、図を使いながら説明してもかまいません。

図8-2に、筆者が仕事をした、ある顧客の例を示します。このフレームワークは、データをエンドツーエンドで管理するために、さまざまな段階にわたって、それぞれの役割が担当する活動をまとめたものです。責任と活動については、この図では高レベルな説明にとどめています。ただし、すべての役割が正しいプロセスに従うようにするには、より詳しいプレイブックやガイドラインでサポートすることをお勧めします。

	データ作成	データプロダクト作成	データ公開	データ要求	データ利用
データオーナー	• データ品質の問題対処の調整 • (機能的な)データギャップの解消	• データコンシューマとのデータニーズの調整	• 利用についてのポリシーと制限事項の提供 • 制約条件の改善	• データ利用の承認 • データ契約の定期的な(四半期ごとの)見直しと契約締結	• 利用状況に関するフィードバックの収集と調整
アプリケーションオーナー	• アプリケーションデータモデルの保守と説明 • アプリケーションの更改プロセス	• データエンジニアと密接に連携しデータパイプラインを開発 • 技術的なメタデータの配信	• データプロダクト作成用のメタデータの配信 • SLAを満たすためのコントロールの実装 • リネージの配信	• データコンシューマのアプリケーションオーナーと技術的な要件についての調整 • 問題の解決	• 利用状況についてのフィードバックの収集 • アプリケーションに関する問題の解消
データスチュワード	• データ品質問題への対処の調整 • データギャップの解消	• ビジネス用語と定義の提供 • ビジネス用語と技術的な属性の関連付け • 機密データの分類	• ドキュメントの改善 • 知識の共有 • データオーナーと協力してポリシーを定義	• データオーナーへフィードバックし、一貫したデータ利用を実現	• データ消費側のデータユーザーに対する指導やトレーニング
データユーザー	• データギャップやデータ品質問題を解決するためのサポート • 要件の共有	• フィードバックの提供	• フィードバックの提供	• データ契約用にデータ利用情報の配信 • データ利用においての制約条件の調整	• フィードバックの提供 • データオーナーやほかのデータユーザーとの知識の共有

図8-2　フレームワークの例

成熟度モデルを導入し、データライフサイクルのさまざまな段階におけるパフォーマンスと成熟度を示すレベルを導入してもよいでしょう。例えば、レベル0はドメインチームのメンバーがトレーニングを受けておらず、データガバナンス活動が行われていないことを意味します。レベル1は、チームメンバーがトレーニングを受け、基本的なことを理解しているが、ガバナンス活動が限定的であることを示します。レベル2以上は、成熟度が高まっていることを示し、レベル5は、チームメンバー全員がデータを正しく管理し、効率的な処理に深く関与していることを示します。

ガバナンスフレームワークは、組織の具体的なニーズに合わせてカスタマイズする必要があります。効果的なものであれば、複雑でもシンプルでもかまいません。また、データ管理の技術的な面だけではなく、組織的な面に焦点を当てることが重要です。

8.1.1.3　ガバナンス組織

データガバナンスを実現するためには、ガバナンス組織（**データガバナンスチーム**と呼ばれることもあります）を整備し、フレームワークが正しく運用されていることを確認する必要があります。このチームのメンバーは一般的に以下のような活動を行います

- 手順と標準が守られていることを監視

- 手順とドキュメントが常にアップデートされていることを確認
- トレーニングと意識向上プログラムの確立
- すべてのドメインに対して、データガバナンス全領域における現在の成熟度レベルについての情報開示
- 新しい従業員への役割の割り当て
- 定期的なレビューの実施
- コンプライアンスを守らせるための監査報告書の作成
- 改善点の洗い出し
- 新しい標準とポリシーの定義
- データ管理に必要なアーキテクチャ要件の策定

ガバナンス組織には、データオーナーやデータスチュワードのほか、データアーキテクトや他部門のマネージャーなど、より上級のメンバーも参加するのが一般的です。ガバナンス組織のメンバーは、最高データ責任者に報告を行います。

データガバナンス組織がさまざまな役割を割り当てる場合、その役割に付随する責任とタスクをフレームワーク上に詳細に記述することが重要です。特にデータオーナー、データユーザー、アプリケーションオーナー、データスチュワードは自らの責任と各担当者の責任を理解しておく必要があります。これらの一連のタスクには、さまざまなプロセスも含まれます（次に説明します）。全体的な責任は通常、RACIマトリクス（**責任分担表**、https://oreil.ly/KgNs7）にまとめられています。さまざまなタスク、役割、責任、誰が責任を負うかがすべてマッピングされています。

役割、フレームワーク、ガバナンス組織は、データガバナンスの基盤として機能します。中央での監督と、責任や活動の割り当ての間でバランスをとりながら、責務が明確になるようにし、責務が重複しないようにします。データガバナンスをより有効に機能させるために、ほかに何が必要でしょうか。

8.1.2　プロセス：データガバナンス活動

データ管理は、ガバナンスフレームワークで定められたすべての活動を、規定されたガイドラインに従って遂行する作業です。ガバナンス組織は、組織全体にわたって、こういう意味でのデータ管理を適切に行わなければなりません。連合型組織や大規模組織では、ガバナンス組織は少し異なる役割を担う場合があります。ガバナンス組織は、ドメイン内で適切なデータガバナンスとはどういう状態かを明確にする責任を負います。このような組織カルチャーの変革に

は、考え方の変革も必要です。すべてのデータガバナンス活動を遂行するのではなく、ほかのユーザーのコーチングとトレーニングにも取り組むべきです。この変革をサポートするために、連合チームが実行しなければならないプロセスについて、ガイドラインとプレイブックを作成する必要があります。ここでは、特に重要な項目をいくつか紹介します。

- データカタログのメタデータ作成プロセスの定義
- データソースの識別、アプリケーションオーナーシップとデータオーナーシップ割り当て
- 個人を特定できる情報（PII）の取り扱いを規定した法規制（GDPRなど）に準拠し、適切なデータ取り扱いのためのポリシーを定義
- 作成時と流通時のデータについて、許容できる外れ値などの品質レベルを定義し、データ品質に関する責任の割り当てと、追跡監視
- データリネージの粒度と、それを提供するために必要なアプリケーションの種類の定義
- データの使用、タグ付け、ラベル付け、セキュリティのために、中央での分類体系とリポジトリを設定
- 新しい法規制がデータ管理に与える影響の調査
- ポリシーがアーキテクチャにしっかりと組み込まれるよう、エンタープライズアーキテクチャと連携
- 中央レベルでマスター管理しなければならないデータの判定
- レポートやダッシュボードなどの情報資産を含めて、データのライフサイクル管理ポリシーの設定
- XML、Parquet、JSONなどの一般的なデータフォーマットのスキーマ要件とプロトコル規格の定義
- メタデータ、データ型、スネークケースやキャメルケースなどの命名規則に関するガイドラインの定義
- ドメインチームがメタデータを正しく提供できるようにサポート
- データスチュワードへの報奨、倫理や、特定のコンテキストにおける機械学習の使用に関する意識の向上など、データを意識するカルチャー形成への取り組み
- データの保存期間の設定
- データモデルが正しく維持されるよう、ユーザーの監視と指導
- データモデリング、オントロジー開発、ビジネス用語集の整備などのための方法論とベストプラクティスの開発
- データカタログとそのメタモデルを管理し、すべての情報資産が適切に表現されていることの確認

- データ管理の原則から外れた部分を特定し、関連するリスクに対処
- データの取り込みと消費に関する原則の設定
- SQLクエリログの監査や外部データへの対応などについて、ガイダンス、ポリシー、フレームワークの策定
- 組織の指針として、守るべきものに関する話し合いを行い、規則、原則、自動化を決定し実施

初期の段階では、これらの活動のすべてではなく、サブセットを選択して行うのが良いでしょう。ガバナンスの計画と実行を管理しやすく実践的なものにするためには、何を**しないか**も合わせて決めておくことが重要です。対象とする活動は、関連性に基づいて選択します。最初の一歩として、何がしっくりくるか、何が理にかなっているかということを考えてください。また、依存関係に基づいて何を解決すべきかを検討します。どのような順序で何をすべきかを考えます。最後に、次世代データアーキテクチャの確立を進めていく中で、施策の定義や見直し方針など、ほかにも実施しなければならない活動があることに注意してください。

8.1.3　効果的で実用的なガバナンスの実現

役割、フレームワーク、プロセスを明確にした上で、次のステップとして、ガバナンスを効果的かつ実用的なものにしましょう。筆者の経験に基づき、以下のような提案をします。

できるだけ早く経営幹部の賛同を得ます。
最初のステップとして重要なのは、達成目標に対して経営幹部の賛同を得ることです。データガバナンス構想は、ボトムアップから始まるか、エンタープライズデータプラットフォームの導入後に始まることが多いです。最初からリーダーのサポートを得ることで、権限付与、権限移譲、リソース不足などに関する問題を避けることができます。

ほかの大規模プログラムとタッグを組みます。
ほかの大規模な変革プログラムと、読者の目標をすり合わせることができないか検討してみてください。無理をしなくても、すでに活動を始めている取り組みを活用できるかもしれません。筆者の以前の職務では、データガバナンスのビジョンを、外部の法規制を遵守するための取り組みと連携させました。通常、このようなプログラムにはすでに多額の予算が組まれ、組織全体が取り組んでいます。

データガバナンスがすべての人に明確な価値を提供できるようにします。
データガバナンスを適切に行えば、作業がやりやすくなります。例えば、機密データがどこで管理されているかを全員が理解すれば、リスクを軽減

できます。また、セルフサービスによるデータ発見やデータへのアクセスも簡単になります。

ローカルチームを信頼します。

大規模な組織では、すべてのデータを監視・管理できる人はどこにもいないため、発想の転換が必要です。境界が明確になり、ドメインにスキル、サービス、コントロールが備わっていると確信が持てたら、信頼境界内で各ドメインがデータを管理できるようにします。

上流データの品質に注目します。

品質の問題をソース（提供側のアプリケーションや提供側に近いところで実行されるプロセス）で解決すれば、ほかの場所で問題が発生しなくなります。

現実的な目標を持ち、すべてのデータを「正しい」ものにできるという思い込みを捨ててください。

コンシューマとそのユースケースに焦点を当て、コンシューマにとっての「良い品質」とは何かを考えましょう。

データガバナンスを一過性の改善と考えないでください。

データガバナンスに終わりはありません。負担を減らしたければ、自動化しましょう。つまり、計算処理可能にするのです。

データガバナンスチームにスキルの高いソフトウェアエンジニアを配置します。

ガバナンスを効果的に行うには、データ管理作業の自動化が不可欠です。例えば、データプロダクトを公開する場合は、事前に自動的に検証を行うようにします。また、手作業でデータプロダクトのカタログを作成するのではなく、プラットフォーム内のサービスで機密データのプロファイリングを行います。

データ管理の基本原則を厳守します。

データガバナンスの主な目的は、基盤となるものを構築することです。そのため、ベースラインと標準を厳守する必要があります。お勧めの方法は、データをソースから直接取得する、所有していないデータの流通を禁止する、オーナーのいないデータを共有しないなどの基本原則を定めることです。次に、アクセスモデルを検討します。通常、計算ベースのアクセスモデルは、消費側の計算レイヤーでデータアクセスと許認可を行います。このモデルは、信頼の移譲モデルに依拠しています。プロバイダー側の管理者がコンシューマ側の管理者にアクセス権を付与し、コンシューマ側の管理者がコンシューマにアクセス権を付与するというものです。ほかの方法としては、データ中心のアクセスモデルがあり、データが存在する場所（例えば、データレイク内）で、データを消費するグループに対して認可が行われます。

進歩を共有します。

読者の作業が、どのような影響を与えるかを示すことが不可欠です。そのため、透明性とコミュニケーションを大切にしましょう。感謝の言葉を伝

え、ロードマップを提示し、率直なフィードバックを集め、重要なマイルストーンの達成を祝いましょう。

創出されたビジネス価値に基づいて成功の度合いを評価します。

影響を明確に示すことは、経営トップの関心とサポートを得るのに効果的です。成果を評価指標で管理することを検討してください。例えば、どれだけのデータ品質の問題が解決されたのか、組織全体におけるデータの可用性はどのくらいなのかを示すなどです。

適切なバランスを見つけ、少しずつ実行します。

すべてのドメインが同じレベルで法規制上の問題に悩まされるわけではないので、ドメインの要件に合わせてガバナンスのレベルを調整してください。データの大半が低リスクであれば、多くの制限や手続きを設ける必要はありません。顧客の住所など、重要なデータ要素に集中し、規模を拡大するときはゆっくりと進めましょう。実際にやってみて学び、できるところから現実的にプロセスを変えていきましょう。

継続的なコミュニケーションを心がけます。

データガバナンスの中には、すべての組織にとって標準的な部分もありますが、多くの部分は、組織の働き方や組織構造に特有のものです。データガバナンスには多くの専門用語が使われます。チームを正しくつないで協力し合うために、よく使われる重要なガバナンス用語と定義を一覧にしてください。また、データガバナンスのメリットをわかりやすく伝えます。こうすることで、変革に対する抵抗をやわらげ、従業員が最初から関われるようになります。

メタデータをスマートに管理します。

多くの作業は、Excelスプレッドシートに手作業でメタデータを記述することが中心となります。しかし、そうしなければならないわけではありません。データカタログにメタデータを自動的に記録したり、統合サービスに標準化を適用したりして、データのリネージをより簡単に収集できるようにしましょう。

データガバナンスを、計画、実行、調整のサイクルの一部にします。

データガバナンスチームは、ほかのチームの進捗状況や課題に目を向けるべきです。サポートする姿勢をとってください。例えば、データを共有したり消費したりするプロセスに時間がかかりすぎる場合、チームはサービスをより分かりやすくしたり、セルフサービスにしたりすべきです。

楽しんでください。

組織内でガバナンスに対する意気込みを生み出す方法を探しましょう。例えば、特定の職務に就く機会を新たに設けたり、若手社員にプレゼンテーションやデモンストレーションを通じてコミュニケーションの練習をさせたりすることが考えられます。また、ワークショップやブログ記事、PI計画会議での特別な報奨などにより、意識と関心を高めましょう。

取り組みへの関心を高めたら、次の課題はすべての活動を効果的にサポートすることです。そのためには、データガバナンスチームに十分なリソースが必要

になります。とりわけ、ツールとメタデータリポジトリが必要です。

8.1.4　データガバナンス支援サービス

これまで述べてきたように、データに関する透明性と信頼性を高めることが重要です。このような信頼を築くには、データガバナンスチームやそのほかのチームが、データに関するデータであるメタデータを、ツールやプラットフォームを通じて、一元的に利用できるようにする必要があります。実際には、データガバナンスのためのメタデータは散在していることが多いため実現は難しくなっています。メタデータは、特定のプラットフォームやツールのコンテキスト内でしか利用できないためです[†1]。そこで必要となるのが、アプリケーション、データ、データオーナーを、より正確に特定・分類するための総合的な戦略です。さらに、これをサポートするアプリケーションとリポジトリを備えたアーキテクチャが必要です。

[†1] 9章では、メタデータ流通の問題を解決するために多くのページを割いています。

データガバナンスを成功させるためには、以下のようなアプリケーションや機能が必要です。

データカタログ
データカタログは、一般的に、ビジネス用語、オーナー、出所、リネージ、ラベル、分類などのメタデータを格納するインベントリです。最近では、データカタログは、ほかの多くのデータ管理ツールや検索ツールと一緒に使われることが多いため、スキャナや、メタデータを格納するためのナレッジグラフが組み込まれていることもあります。9章では、これらの項目に関する詳細な説明を行います。

アプリケーションリポジトリ
アプリケーションリポジトリは、すべてのアプリケーションと、そのアプリケーションオーナーを管理するための、中央リポジトリ（ITサービス管理システム）（https://oreil.ly/sIKV-）です。さらに、このリポジトリには、本番稼働状況、ベンダー製品、所定のコントロールに基づくアプリケーションの機密性、完全性、可用性の評価などの情報を保持することができます。また、このリポジトリには、ServiceNow（https://www.servicenow.com）などのサードパーティソフトウェアコンポーネントを使用することもできます。

一意なデータ要素のリスト

このリストは、組織内のすべての一意なデータ（そのオーナーシップを含む）全体を管理するリポジトリです。7章で説明したように、データはデータセットという形式で論理的に登録されます。1つのアプリケーションに複数のデータオーナーが存在し、複数の物理データセットが同じアプリケーションから生成される可能性があるからです。その結果、データセットとアプリケーションの関係は、多対多の関係となります。一意なデータを扱うリポジトリは、個人情報とその使用目的、エンタープライズデータの利用、データ利用についての制限事項など、個々のデータ要素の分類を管理することもできます。

データ契約アプリケーション（DCA、Data contract application）

このアプリケーションには、データ共有の目的、安全対策、変更条件、保証、プライバシー制限、有効期限など、データオーナー、データユーザー、データコンシューマなどの間で交わされる、すべてのデータ契約が登録されます。DCAは、本章の後半で説明するセキュリティアーキテクチャにおいて重要な役割を担っています。DCAは、後で学ぶように、ポリシー管理点（PAP）またはポリシー情報点（PIP）として機能し、認可判断を下すための評価と発行に関する情報を与えます。これらの要素については、「8.2　データセキュリティ」で詳しく説明します。

DCAを構築せず、サードパーティベンダーのデータセキュリティアプリケーションをそのまま使用する場合、その特定のベンダーと密結合することになります。多くのセキュリティアプリケーションは、サイロ内でしか動作しないか、一部のテクノロジーしかサポートしていません。すべてのデータについて、特定のテクノロジーに依存しないような全体的なセキュリティの枠組みを得たい場合は、分離しておく必要があります。

メタデータリポジトリ

メタデータリポジトリとは、データユーザーがデータに関する情報を検索・管理するためのデータベースと関連ツールのことです。メタデータリポジトリとして、サードパーティのソフトウェアコンポーネントや、内製のソリューションを使用することもできます。メタデータの管理に関するより具体的なガイダンスは、9章で説明します。

ナレッジグラフ

ナレッジグラフは、グラフ構造化されたデータモデルやトポロジーを使用してデータを統合する知識ベースです。データガバナンスのためには、相関や関係を発見することが重要な場合があります。詳細は9章で説明します。

データスキャナとプロファイリングツール

データの品質レベル、スキーマ情報、変換やリネージ情報などの情報を収集するために、データを処理・検査するスキャナやプロファイリングツールが必要です。最新のデータカタログでは、これらの機能がデフォルトで組み込まれています。また、スキャンとプロファイリングに特化した製品も存在します。

これらのデータガバナンス関連のアプリケーションや機能はすべて連携して、データの統合ビューを提供するものでなければなりません。商用ツールや内製アプリケーションを使用することもできます。また、特定のタスクに最適化されたツールに特定の部分だけを任せることもできます。

特に注意が必要なコンポーネントはDCAです。ドメイン間で責任が分散している連合アーキテクチャでは、依存関係を監督し、データ使用に関するインサイトを得ることが難しくなります。そこで登場するのがデータ契約です。

8.1.5　データ契約

データ契約とは、データプロバイダーとデータコンシューマの間で、どのようなデータをどのような目的で利用するかについて正式に合意することです。データ契約はなぜ重要なのでしょうか。データ契約は、誰がどのようなデータプロダクトを所有するのかについての情報を提供し、標準の策定とデータパイプラインの管理を信頼性をもってサポートし、どのようなデータプロダクトが、誰によって、何のために消費されているのかについての情報を提供します。つまり、データ契約は堅牢なデータ管理に不可欠です。

データプロダクトの流通と利用に関する問題を、2つの観点で考えることをお勧めします。まず、データパイプラインの取り扱いやデータの安定性に関する要望など、技術的な問題があります。次に、データ共有の目的（利用目的、プライバシー保護や、制限など）について取り決める、ビジネス上の関心事です。一般的に、それぞれの側面で担当する役割が異なります。技術的な問題については、アプリケーションオーナーやデータエンジニアに相談するのが一般的です。ビジネス上の関心事については、データオーナー、データユーザー、データスチュワードに相談するのが一般的です。

データ契約は、データ配信契約やサービス契約のようなものです。データプロダクトが普及し、広く使われるようになると、バージョン管理や互換性の管理が必要になるため、データ契約は重要です。大規模なアーキテクチャや分散アーキテクチャでは、変更や依存関係を把握するのが難しくなるからです。ほかのアプリケーションからデータにアクセスしたり、データを消費したりするアプリケーションは、相互依存などの密結合に常に悩まされます。例えば、データ構造に破壊的な変更があれば、ほかのアプリケーションに直接影響を及ぼす可能性があります。多くのアプリケーションが互いに結合している場合、連鎖的に影響が波及することもあります。1つのアプリケーションに小さな変更が加えられただけでも、ほかの多くのアプリケーションに次々と調整を行わなければならないこともあります。そのため、多くのアーキテクトやソフトウェアエンジニアは、結合アーキテクチャの構築を避けようとします。

この技術的問題を解決するのがデータ契約です。データ契約はインタフェースの互換性を保証し、サービス条件とサービスレベルアグリーメント（SLA）が含まれます。同時に、組織に透明性を提供します。**例8-1**に、データ契約をメタデータレコードとして実装する例を示します。

データ契約は、どのようなデータの利用が許可されているかを示します。データ契約には、使用方法に関する詳細（例えば、開発、テスト、本番環境での使用のみ許可されるかどうか）や、品質、配信、インタフェースに関するメタデータが含まれることがあります。また、運用時間、許容されるエラー率、可用性、非推奨、バージョン番号などの情報も含まれる場合があります。

例8-1　データ契約の情報を保持するメタデータレコードの例

```
{
  "@AgreementId": "1342",
  "contactPoint": {
    "ConsumerId": "894",
    "fn": "Marketing Department",
    "hasEmail": "mailto:email@example.com"
  },
  "ApplicationId": "201",
  "Description": "<p>このデータ契約は、HRの領域内でのマーケティングデータの
  使用について定めています。このデータの使用は人事部のみに限定されます。
  データには従業員や顧客に関する機密情報が含まれている場合があります。</p>",
  "DataRequestType": "dcat:FlatFile",
  "IssuedDate": "2022-11-26",
```

```
    "StartingDate": "2022-12-01",
    "ExpirationData": null,
    "scope": [
      "DEVELOPMENT"
    ],
    "purpose": [
      "HR_ONLY"
    ],
    "dataElements": [
      "fd11d32f-4944-4bd9-a563-36d0f891e649",
      "345f0539-f3c7-4547-a2ab-cf6b66c675ce",
      "ff0e9c26-0f96-4370-8e39-7d78b27ffe88",
      "7ca735c1-20dd-43f1-a7a9-e5719340e4fa",
      "3b7c7926-7d39-4257-8029-dacc9ee22ecf"
    ],
    "ApprovalDate": "2022-11-27",
    "ApprovalFlag": true
  }
```

例8-1では、エンティティに対して、ファイルやデータソースの場所を示すパスを使用するのではなく、グローバル一意識別子（GUID）を使用しています。GUIDを使用する理由は、データが動的に処理されフォルダに格納されるので、データプロダクトが重複したり、アドレスの場所が変更されたりする可能性があるからです。GUIDは、常に変化せず、データが物理的に保存されている実際の場所に関連付けられるため、このような問題を解決することができます。

さまざまな組織での筆者の経験では、データ契約はメタデータ駆動型のインジェストやデータ品質管理フレームワークの一部として実装されることが多かったです[†2]。このような設計におけるデータ契約は、破壊的な変更を検出することで、データ配信の完全性を保証します。例えば、データ契約は、コードリ

ポジトリの実行テストテンプレートとして保存され、（スキーマ、データ型、ファイル形式の検証など）データパイプライン内で重要な役割を果たします。

[†2] データ契約に関するブログ、動画、ツール、そのほかのリソースについて厳選されたリストが、AltimateAIのGitHubリポジトリ（https://oreil.ly/pMUcF）にあります。

また、データ契約をデータプロダクトアーキテクチャとは別の場所に保管している組織も見かけます。例えば、中央のデータ契約リポジトリやデータカタログなどです。**例8-1**は、この保管方法に適した形式です。データ契約を別の場所に保管するのは、実装の手間がかかります。なぜなら、契約に記述されていることと、実際のデータプロダクトアーキテクチャ内でデータセットを検証する方法を変換する必要があるからです。分散アーキテクチャでは、ドメイン間でデータパイプラインフレームワークを標準化する必要があります。標準化すれば、ドメインは共通の作業方法を用います。ドメインは自らデータを処理するので、コントロールと責任はドメインに帰属します。一方で、フレームワークと契約メタデータは中央のガバナンス下に置かれます。このモデルを検討する場合は、スキーマ検証やデータカタログ情報の管理など、基本的なことから始めましょう。この取り組みの一環として、プロセスを構築し、Great Expectations（https://greatexpectations.io）やdbt test（https://oreil.ly/9ougy）のようなライブラリを使用してコントロールし、データ契約作成プロセスの中で技術的なデータ品質を検証します。次に、データプロバイダーとコンシューマ間のハンドシェイクを実現するコントロールとワークフローを導入します。例えば、テスト用テンプレートがプルリクエストされたときに、ドメインが承認するようにします（https://oreil.ly/mdWph）。

データオブザーバビリティとは、組織がデータ資産内のデータの健全性を把握できる能力のことです。データの鮮度、完全性、量、リネージ、品質、そしてこれらすべての次元におけるトレンドに関するものです。データ契約は、データの消費と使用のパターンを定義することで、このような問題に対応できます。

規模を拡大しつづけるには、データにオブザーバビリティを持たせる必要があります。そのためには、データパイプラインの統計情報を収集する必要があります。この情報は、同じ契約リポジトリやデータベースに保管することができます。パイプラインの全体的な鮮度、健全性、ステータスを確認するには、このオブザーバビリティに関する情報が必要です。

8.1.5.1　利用規約

利用規約はデータ契約に不可欠なものです。説明したように、利用契約には利用目的、プライバシーに関する事項、および制限事項が含まれます。利用契約はインタフェースに依存せず、データセキュリティ管理のための情報として活用することができます。どのような目的であれば、データを合法的に利用できるのかも知ることができます。これらの契約には、例えば、データに適用されるフィルタやセキュリティ保護の詳細、消費されたデータや新たに作成されたデータの共有に関する制限などが含まれます。

また、利用規約は、データ利用に関する誤解を防ぐものでもあります。データを共有する前に、ドメインはデータ共有とデータ使用の問題について話し合うべきです。合意に達したら、その合意をデータ共有合意書としてまとめます。このような合意は、データ品質、履歴管理、データライフサイクル管理、再配布などの機能面が含まれる場合もあります。このような共通の理解に至るという方法は、法規制の観点で重要であるだけでなく、組織に価値をもたらします。

利用規約やデータ契約全般における属性は、ビジネスデータカタログの要素と明確に対応付ける必要があります。このカタログには、データの使用方法に関する情報が含まれています。つまり、意味的なコンテキストが常に提供され、

データ属性とビジネス用語の間に必ずリンクが作成されます。これにより、コンシューマはビジネス要件から実際の実装にどのように変換されたかを理解することができます。このことがどの程度重要かにもよりますが、これらの関係が維持されるようにポリシーを実装することを検討すると良いでしょう。例えば、データプロダクト属性がビジネス用語にリンクされている場合にのみ、契約に含めることを許可するようにします。関係や定義の変更など、コンテキスト上の変更にも同じポリシーを適用できます。

最後に一言述べておきます。倫理面での使用方法や再配布に関しては、自動化したり強制したりするのが難しいため、緩い合意がなされることがよくあります。ただし、合意が守られているかどうかを定期的にレビューすれば、監査フレームワークを確立できます。

8.1.5.2　始めるためのベストプラクティス

データ契約はどのように始めるべきでしょうか。ゆっくりと始めてください。課題のほとんどは、組織面での課題です。あまり多くの変更を一度に行わないようにしましょう。データ契約はカルチャー的な変革です。データユーザーはデータ契約を習熟し、データオーナーシップの重要性を理解する必要があります。また、移行にあたっては、メタデータ属性の数が少なすぎず、多すぎず、ちょうど良いところを見つける必要があります。移行そのものについては、以下のプロセスをお勧めします。

1. 何よりもまず、オーナーシップを設定し、データパイプラインを技術的に安定させてください。パイプラインが不安定で、予期しない破壊的な変更を受ける可能性がある場合、ユースケースのどれもが本番環境に移行できません。
2. プロセスを整備しましょう。物事を複雑にしすぎないようにします。例えば、Microsoft Formsのようなツールでデザインしたシンプルなフォームやテンプレートから始めてもよいでしょう。わかりやすく、簡潔な表現で作成しましょう。手作業のプロセスも容認しましょう。最初のメタデータ要件は最小限に抑えましょう。最初のフェーズは、カルチャーの変革を進め、その間に要件を集めていきます。メタデータ要件が安定するまで繰り返しましょう。
3. 最初のプロセスが動き出したら、手動フォームをウェブベースのアプリケーションや、データベース、メッセージキューに置き換えてみましょう。この段階では、中央のデータガバナンスチームが引き続き管理することになります。データアクセスは一般的に粗視化されるので、コンテナ、フォ

ルダ、ファイルを標準化しましょう。データアクセスポリシーやアクセスコントロールリストを自動的にプロビジョニングするために、REST APIを活用するようにしてください。例えば、データオーナーが承認するたびにWebhook（https://oreil.ly/yJCem）が呼び出され、別の機能を起動して、カタログを呼び出し、URIを要求し、アクセス権を更新するようにします。

4. 次に、データ契約を翻訳し、ユニットテストやデータ検証などに反映させて、自動化します。このようにすれば、データ契約が追加されるたびに、配備後の処理が行われます。例えば、APIを呼び出して、テストテンプレートを自動的に追加したり、データ契約書を取得してスキーマ検証の入力として使用するようにデータインジェストフレームワークを変更したりします。
5. 次の段階では、より高度なワークフローを導入して承認を処理するようにします。この時点から、データオーナーまたはデータスチュワードをリーダーとして配置します。中央のデータガバナンスチームが後方から監督し、すべてのデータ契約を定期的にレビューします。この段階までに、利用可能なデータプロダクトを一覧にしたデータカタログを作成しておく必要があります。データセキュリティ（セキュリティの施行機能）を改善します。動的ビューを自動的に導入して、列や行のフィルタをより細かく選択できるようにします。悪用を防ぐために、動的データマスキングのような技術を検討します。きめ細かなデータアクセスを実現するために、データプロバイダーに、データプロダクトを拡張してフィルタリング用のメタデータを追加するよう要請します。
6. 最終的には、すべてがセルフサービスで完全に自動化されます。これには、自動化されたセキュリティの施行や、データ承認用の機械学習が必要です。例えば、セキュアなビューは承認後に自動的に配備されるようにします。

データ契約は、比較的新しいデータ管理方法です。データ契約は、依存関係やデータの使用状況を透明化するために重要です。まずは小さく始めて、技術的な安定性と標準化に集中しましょう。そして、教訓から学ぶプロセスを用いて反復します。データガバナンスは不可欠ですが、やりすぎるとかえってコストがかさみます。ゆっくりと構築し、自動化しましょう。

ここまでのところでわかったように、データガバナンスは次に説明するデータセキュリティに不可欠です。データセキュリティには、強固なガバナンスフレームワークとメタデータの基盤が必要です。ドメインがデータのオーナーシッ

プを持ち、データを正確に記述・分類しなければ、機密性の高いデータを保護することは不可能です。

8.2　データセキュリティ

1章で説明したように、データセキュリティは、人、プロセス、テクノロジーなど、データの保護に関わるすべての活動を対象としています。特に、PII、個人の健康情報、銀行の情報、知的財産に関する情報などの機密データを、犯罪者や、ハッカー、攻撃者、競合他社の手に渡らないようにすることが重要です。

問題は、データが流動的であり、今日ではもはや単一のモノリスで管理されていないことです。データは非中央集権的であり、多くのシステムや環境に分散しています。データが分散していると、ユーザーがデータを手にしたときに行うことをコントロールするのが難しくなります。例えば、ほかのソースのデータと組み合わせて非倫理的な分析を行うことはないのでしょうか。また、データのコンテキストを完全に把握することなく、データを保護することも困難です。組織再編に関連する人事データは、社員旅行や祝賀会を企画する場合とは異なる意味と価値を持ちます。

それよりもはるかに大きな問題は、大企業が扱っているデータが大量であることです。連合データは、データソース、オーナー、コンシューマのニーズや要件がすべて集約されたるつぼのようなものです。個々のソースとそれに対応するデータ要素には、それぞれ異なるコンテキスト、品質レベル、分類、使用目的の制約、オーナー、評価などが含まれます。新たなソース、データプロダクト、ユースケースは絶えず追加されていきます。これらすべてのデータを表現し、管理し、保護するためには、膨大な数のセキュリティルールとポリシーが必要となります。

企業におけるデータセキュリティは、最高情報セキュリティ責任者（CISO）が率いるセキュリティ専門の部署によって実施されるのが一般的です。CISOは、企業のビジョン、戦略、情報資産、テクノロジーを適切に保護するためのプロセスを確立・維持する役割を担う経営層のことです。CISOは、エンタープライズアーキテクチャやデータガバナンス組織と密接に連携し、セキュリティのビジョンと目標が企業全体に正しく組み込まれるようにします。

8.2.1　サイロ化した現在のやり方

多くの企業が導入しているセキュリティ対策と、専門家が推奨しているものとの間には、大きな隔たりがあります。多くのコンサルタント会社は、**データセントリックセキュリティ**という言葉を用いて、セキュリティはネットワーク、サーバー、アプリケーションではなく、データそのものに焦点を合わせるべきだと力説しています。しかし、実際には、現在のセキュリティ対策は主にサイロ（データウェアハウスやデータレイク）に集中しています。なぜなら、データが大量にあり、ユーザーが無数の組み合わせを行う可能性があるため、リスクが高く、細心の注意を払う必要があるからです。

APIベースのアーキテクチャやイベント駆動型アーキテクチャの場合、多くの企業で、さまざまな手順、分類、ツール、機能を用いてセキュリティモデルが実装されています。これらのアーキテクチャにおけるセキュリティは、これらのプラットフォームを流れるデータではなく、エンドポイントに重点を置いています。データの分類や、それに関連するコンテキストは、運用上のユースケースにおいてはほとんど使われません。筆者の考えでは、データセントリックセキュリティモデルでは、信頼境界に着目し、その背後にあるガバナンスメタデータを利用すべきです。そこで、この点について、項を分けて説明していきます。

8.2.2　信頼境界

連合アーキテクチャでは、ドメイン境界は信頼境界として扱われます（https://oreil.ly/sRlij）。具体的には、ドメイン自体にある程度の信頼が与えられているということです。したがって、どのようなセキュリティモデルを設定するか、データを内部的にどのように分類するか、どのデータを誰が使用できるかについては、ある程度まで、ドメイン自身が決定することができます。このような信頼が存在するのは、ドメイン内ではコンテキストが把握されているからです。ドメイン境界内で作業している誰もが、そこで管理されているデータに付随するリスクと脅威を十分に理解できていると想定できます。

ドメインを越えてデータを移動する場合、信頼のレベルが変わるため、異なるルールが適用されます。ほかのドメインでは、データを元のコンテキスト以外で使用する際に、どのようなリスクが発生するか認識しにくいのも理由の1つです。このようなことにより、プライバシーリスクが拡大する事態を招くおそれがあります。したがって、ドメイン境界（データプロダクト、API、イベントへのインタフェース）のエッジでセキュリティを管理することが重要です。信頼境界を管理するためのお勧めの方法は、以下の一連の作業を実行することです。

- データの分類と使用目的の明確化を行い、どのデータに対してどのレベルの保護を提供しなければならないかをドメインが認識できるようにします。
- 信頼境界を越えるデータについて、データ契約を締結しましょう。どのデータがどのような目的で使用されるのか、また適用されている保護レベルが十分であるのかについて透明性が確保されます。
- 監視の仕組みを構築し、どのようなデータが信頼境界を越えて移動したのかを確実に把握できるようにします。この原則を守るには、データガバナンスやカタログソリューションにリネージを組み込む必要があります。
- IDベースのアクセス制御、保管時および転送時のデータの暗号化、鍵管理サービスの利用、セキュリティログおよび監査サービスの利用、ユーザーの2要素認証、権限のないユーザーに対するデータの難読化やマスキングなどを自動的に実施するポリシーとコントロールを導入します。

最終的には、信頼境界のエッジにセキュリティコントロールを置き、あらゆるタイプのデータ流通に対して、信頼レベルに基づいてセキュリティコントロールが一貫して機能するようにしなければなりません。このような成熟した状態に達するには、中央セキュリティサービス、クロスドメインガバナンス、強力なガイダンスが必要です。すべてのエッジで高いレベルの管理を行うことは容易ではありません。データを一貫して正しく分類するには、チームと専門家が必要です。そのため、中央での分類体系が必要になります。さらに、これらの分類に応じたデータの使い方についても合意する必要があります。また、これらすべての情報を入力とする統一データセキュリティモデルを導入する必要もあります。次の項でこれらの点について検討し、実用的な例を挙げて具体的に説明します。

8.2.3　データ分類とラベル

分類とラベルはデータ管理において重要です。データを関連するカテゴリに分類することで、効率的にデータを使用したり保護したりすることができます。基本的には、データを分類することで、データを検索しやすく、取り出しやすくなります。しかし、それだけではなく、セキュリティ、コンプライアンス、法規制のために用いることもできます。例えば、セキュリティの分類は、ユーザーが見ることができるものを制限するときに活用できます。データ分類のリストは、中央で管理するようにしてください。また、あまり分類を多くしすぎないでください。

ドキュメント、画像、ログファイルなどの非構造化データも分類しなければならないのでしょうか。

もちろんです。構造化データだけを分類するわけではありません。非構造化データも半構造化データも、同じ分類スキームで完全に分類してください。

セキュリティ分類としては、`Personal Names`（個人名）、`Social Security number`（社会保障番号）、`Religion`（宗教）、`Gender`（性別）、`Employee information`（従業員情報）、`Commercial company information`（商社情報）、`Credit Card Number`（クレジットカード番号）というような項目が考えられます。これらの分類を使用して自動ラベル付けルールを設定する場合は、`Highly Confidential`（極秘）、`Confidential`（機密）、`General`（一般）、`Public`（公開）などのラベルを使用します。例えば、自動ラベル付けルールでは、`Credit Card Number`分類を持つすべてのデータに自動的に`Highly Confidential`というラベルを付けます。

個人情報保護とコンプライアンス

個人情報とユーザーの同意をうまく管理するためには、データガバナンス、セキュリティ、マスターデータ管理の3つを組み合わせることが重要です。データガバナンスは、プロセス、分類、ラベルを管理します。これにより、どのデータが機密性が高く、細心の注意を払って扱われるべきかを確認することができます。データセキュリティは、データへのアクセスを制限します。マスターデータ管理は、10章で学ぶように、データのマッチングと識別に関するルールを管理します。このデータ管理を使って、顧客を一意に識別し、どのような種類の同意がなされたかを把握します。このように、GDPRやCCPAなどの法規制を遵守するためには、特定のデータ管理分野に注力すれば良いというものではありません。コンプライアンスへの取り組みは、エンドツーエンドで統合されたデータ管理から始まります。したがって、データカタログはETLの後で行うのではなく、ソースから始める必要があります。

ラベルを使用する利点は、ポリシーのルールがデータ自身から分離されることです。例えば、法規制によって、PIIに特別な注意を払わなければならなくなったとしても、すべてのデータをラベル付けしなおす必要はありません。分類スキームがしっかりしていれば、制限は自動的に適用されます。

高度に非中央集権化された環境でのPIIの保護は、複雑すぎて、問題が発生しやすいと考えてる大企業も少なくありません。このことを認識している企業は、PIIとタグ付けされたすべてのソースデータに対して難読化や、マスキング、暗号化などの対応を徹底しています。

分類は重要です。分類はポリシーをコントロールする役割を果たし、データアクセスを自動的に制限してくれるからです。データが非常に重要であり、高いリスクが存在する場合には特に効果的です。データプロダクトは、データアクセスの中心となるものなので、すべてのデータ要素を分類する必要があります[†3]。

[†3] 例えば、行のような物理データを分類する場合、分類や分類に対する関連付けは、データ自体にカプセル化されます。

8.2.4　データ利用分類

データ利用、セキュリティ、ディスカバラビリティを適切にコントロールしたいのであれば、データ利用分類を利用して、特定のシナリオやユースケースでのみデータを利用できるようにしましょう。このリストも中央で管理するのが最適です。また、「分類しすぎ」は望ましくありません。あまりに分類が多いと、ユーザーが選択しにくくなります。データ利用分類の具体例を以下に示します。

`DATA_SCIENCE`

研究や、データから知見を見出すためのもの

`AD_HOC_USAGE`

繰り返し作業がない、例えば、その場限りのレポート作成用

`HR_ONLY`

人事に関連する業務用

`FINANCIAL_REPORTING`

財務諸表やリスク報告書の作成用

`DQ_INVESTIGATION`

データ品質の探求・調査用

データ利用分類は、ユーザーがデータを見ることができるかや、データを使って何ができるかに影響します。例えば、参照データを使って、データ利用分類とデータ分類の組み合わせを管理する場合を想像してみてください。このようなテーブルは、データ契約のプロセスで入力情報として使用できます。具体的には、`HR_ONLY`を使用して、人事部門に所属する全従業員をホワイトリストに登録し、`Confidential`や`Highly Confidential`とラベル付けされたデータの閲覧を許可することができます。

ラベルと分類は、より大規模なセキュリティ管理に不可欠です。次の項では、ラベルと分類がセキュリティの判断のための情報となるような、統一的なデータセキュリティフレームワークを提案します。

8.2.5　統合データセキュリティ

データセキュリティを実現する場合、セキュリティ要件をデータプラットフォームとサービスに最初から組み込むことがお勧めです。セキュリティリスクにうまく対処するには、2つのレベルでコントロールを実現する必要があります。最初のレベルは、データセキュリティ管理です。このレベルのコントロールには、データアクセス、データマスキング、データ暗号化、データ利用監視、IDプロバイダーなどが含まれます。2つ目のレベル（インフラストラクチャーレベル）のコントロールでは、隔離、ネットワーク暗号化、ファイアウォールなどに対応します。データ管理という意味では、最初のレベルだけが対象となります。

データセキュリティ管理の中で、基本となる部分はアクセス管理です。アクセスとは、データベースやアプリケーション内に保存されているデータを閲覧したり、データを取り出したりできることです。誰がデータにアクセスできるかを制御する方法として、よく使われるデータアクセス制御モデルがあります。

アクセス制御リスト（**ACL**、access control list）、**ロールベースアクセス制御**（**RBAC**、role-based access control）、**属性ベースアクセス制御**（**ABAC**、attribute-based access control）などです。これらのモデルを理解し、どのように使用するかを見ていきましょう。

ほとんどの企業はACLとRBACから始めます。RBACは、**ロールベースセキュリティ**とも呼ばれるものです。認可されたユーザーだけがシステムにアクセスできるように制限する仕組みです。図8-3に示すように、このモデルの考え方は、すべてのユーザー（従業員）には、権限と制限を備えたロール（役割）が割り当てられるというものです。割り当てられたロールが適切な権限を持っている場合にのみ、ユーザーはデータにアクセスしたり、操作を実行したりできます。

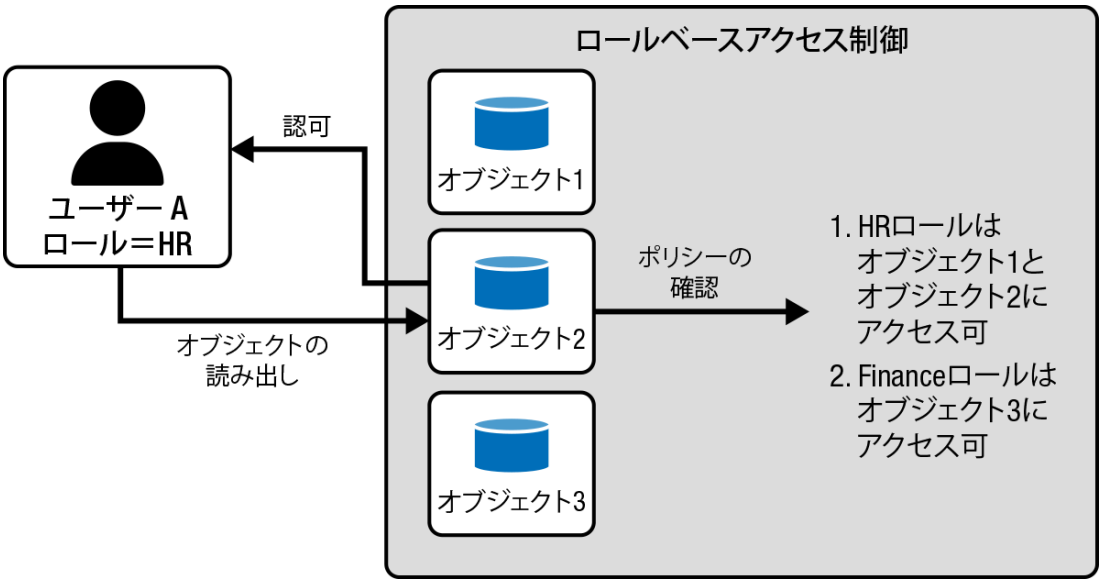

図8-3　RBACを使ってシステムアクセスを制限する

RBACの一番の欠点は、「ロールの爆発」です。大きな組織内では、数多くのさまざまなロールが存在します。部門、下位部門、さまざまな職務に対して多数の異なるロールが存在します。これらすべてのロールを管理することは、非常に複雑になるリスクがあります。粒度の荒いロールモデルを使わない場合、何千もの異なるロールが存在することになります。また、RBACは静的なものであるため、ユーザーの位置、時間、デバイス情報などのコンテキスト情報を活用できないことも問題になります。

RBACはACLとよく一緒に使われます。ACLでは、管理対象のオブジェクトに権限が直接付与されます。例えば、図8-4で示したACL権限テーブルは、計算機リソースへのアクセスを管理するためのものです。これは、どのユーザーがオ

ブジェクトにアクセスでき、どの操作を実行できるかをオペレーティングシステムに指定します。各ユーザー用のエントリーがあり、各オブジェクトのセキュリティ属性に関連付けられます。

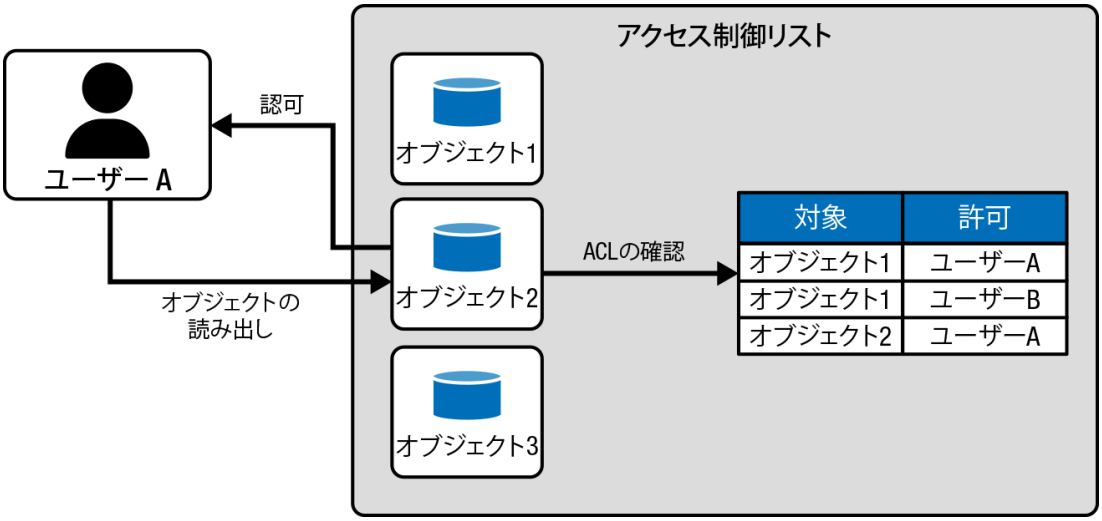

図8-4　ACLを使用して、セキュリティプリンシパル（ユーザー、グループ、サービスプリンシパル、管理対象ID）が操作を実行する権限を持っているかどうかを判断する

ACLは、個々のユーザーレベルや低レベルのデータに対するセキュリティ実装に適しています。一方、RBACは、組織全体のセキュリティシステムとして、組織の管理者が利用するものです。例えば、特定のオブジェクトへの書き込みアクセスを付与することはACLで実現できますが、ユーザーがオブジェクトをどのように変更しても良いかを指定することはACLではできません。

これに対して、ABACは高度なセキュリティ手法です。RBACとACLの欠点の一部を解決するものです。ABACのポリシーは、さまざまな属性を組み合わせます。これらのポリシーは、分類やメタデータのプロパティなど、データそのものに基づくこともあれば、システムのコンテキスト、ユーザー（役割、地理的な位置、デバイスのプロパティなど）、データに対して実行される操作（読み出し、挿入、更新、削除）に基づくものもあります。

図8-5は、さまざまな属性を組み合わせて、より複雑な判断を行う例を示しています。

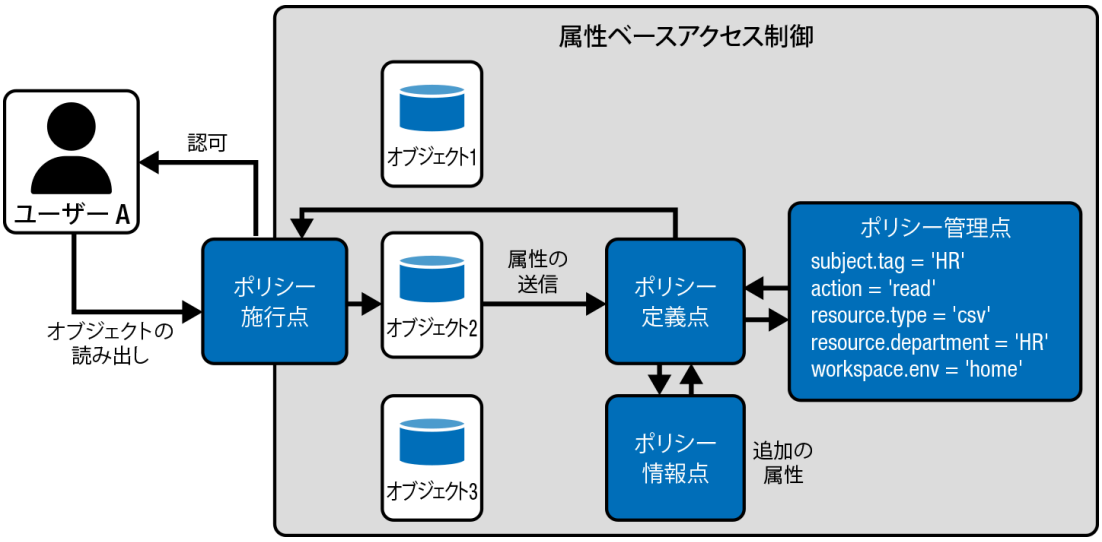

図8-5　アクセス制御にABACを使用

ABACには、図8-5に示したような推奨アーキテクチャがあります。このアーキテクチャは、以下の4つのコンポーネントから構成されます。

ポリシー施行点（PEP、Policy Enforcement Point）
PEPはデータを保護する役割を担っています。データ要求（クエリ）を検査し、承認要求を生成します。承認要求は、検証・認可のためにポリシー定義点に送信されます。

ポリシー定義点（PDP、Policy Desision Point）
PDPはABACの中核となるコンポーネントです。PDPは受信した要求を、すべての属性に対して、定義済みのセキュリティポリシーに照らし合わせて検証します。PDPは、ポリシーに基づき、認可または拒否の決定を返します。そして、PDPはその決定と許可・拒否の理由をPEPに通知します。

ポリシー情報点（PIP、Policy Information Point）
PDPは、PIPを使って外部ソースデータを活用することができます。例えば、IDプロバイダーを呼び出したときのユーザー属性などのデータです。

ポリシー管理点（PAP、Policy Administration Point）
PAPは、エンタープライズセキュリティポリシーのすべてを管理するリポジトリです。一般的に、PAPは監視やログ機能も備えており、ユーザーフレンドリーなインタフェースを持っています。

ABACの具体例を挙げます。メタデータ属性`Employee Information`タグで分類された機密性の高い人事データを考えてみてください。人事部以外の従業員がこのタグを持つデータにアクセスしようとすると、PDPは拒否を返します。ABAC内で属性を組み合わせることもできます。人事の例では、データにアクセスしようとする環境を考慮するようにも拡張できます。例えば、在宅勤務の場合と会社環境からアクセスする場合で、許可・拒否を変えるようなことも実現できます。

8.2.6　IDプロバイダー

RBACおよびABACを連合型環境や分散環境で使う場合、**IDP（IDプロバイダー**、identity provider）が重要なコンポーネントになります。IDPは、ユーザーから属性を取得する外部ソースです。IDPはユーザー認証をサービスとして提供し、Webサイト、CRMアプリケーション、ファイルサーバーなど、ほかのシステムのサインイン処理を行うためによく使われます。有名なIDPには、Microsoft Active Directory（AD）などがあります。また、OpenLDAP（https://www.openldap.org）をベースに実装されたものも良く使われています。

現時点では、認証には、一般的なオープンプロトコルが2つあります。SAMLとOpenID Connectです。SAMLは Security Assertion Markup Languageの略です。認可と認証のデータを交換するためのXML標準に基づいています。OpenIDはSAMLと似たような仕組みですが、よりオープンな仕組みになっています。Microsoft、Facebook、Google、PayPal、Yahooなどの大企業で利用されています。また、このコンテキストでOAuthが話題になることもあります。ただし、OAuthは認可プロセスだけに使われ、認証には使用されません。この分野でよく耳にするものとして、**シングルサインオン（SSO**、single sign-on）もあります。SSOでは、その名の通り、ユーザーはスマートカードや、ユーザー名・パスワードなどの認証情報を一度入力するだけで認証が完了します。その後、再度認証することなく複数のアプリケーションにアクセスできるようになります。

8.2.7　実際の例

この項では、セキュリティアーキテクチャを具体化するために、ソリューション設計について説明します。**図8-6**は、4章で説明したデータプロダクトアーキテクチャをベースとしたアーキテクチャの上側の部分です。このアーキテクチャには、必要となる、すべてのメタデータとセキュリティコンポーネントが含まれています。

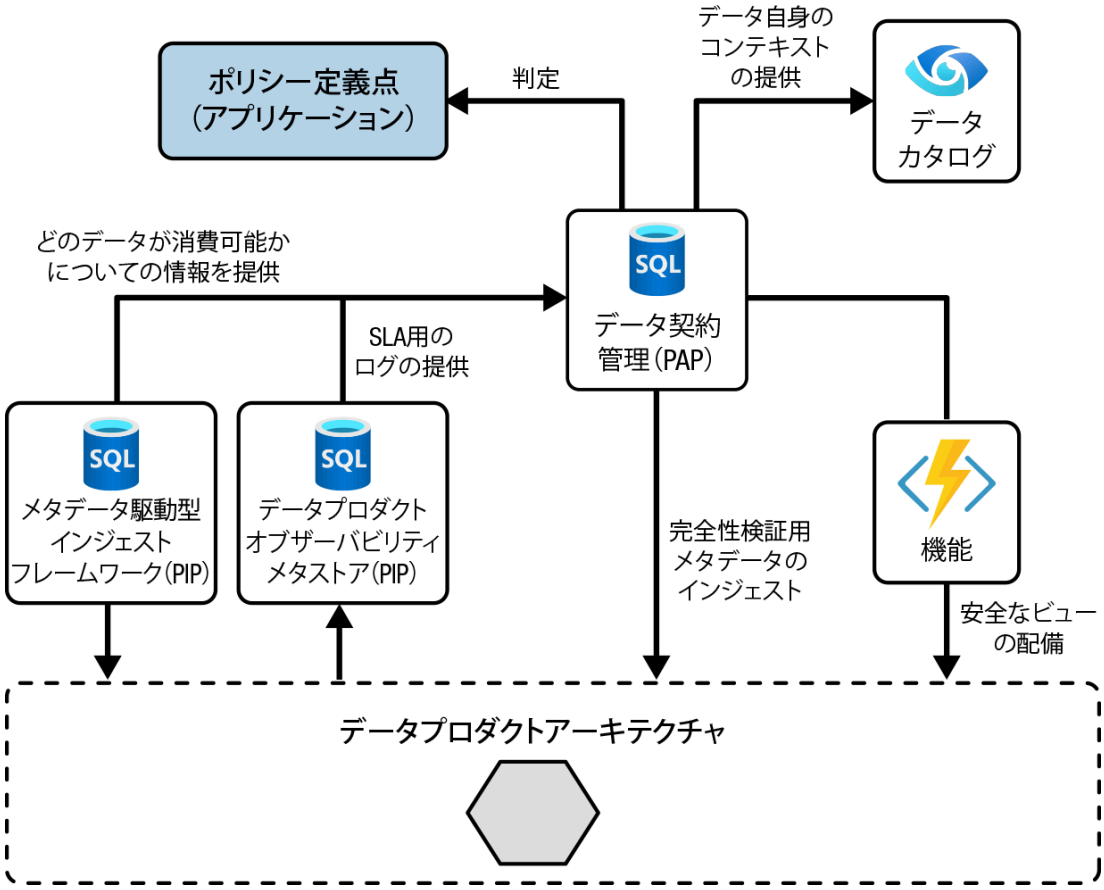

図8-6　セキュリティコンポーネントの連携によるデータセキュリティの大規模化

図8-6に示されているコンポーネントは、アーキテクチャ全体の半分でしかありません。図8-7に示すのは、残りの半分、つまり下側の部分です。この設計では、データプロダクトへの安全なアクセスは仮想化されています。どのコンシューマがどのような利用を許可されているかという情報は、上側のセキュリティアーキテクチャが提供してくれます。

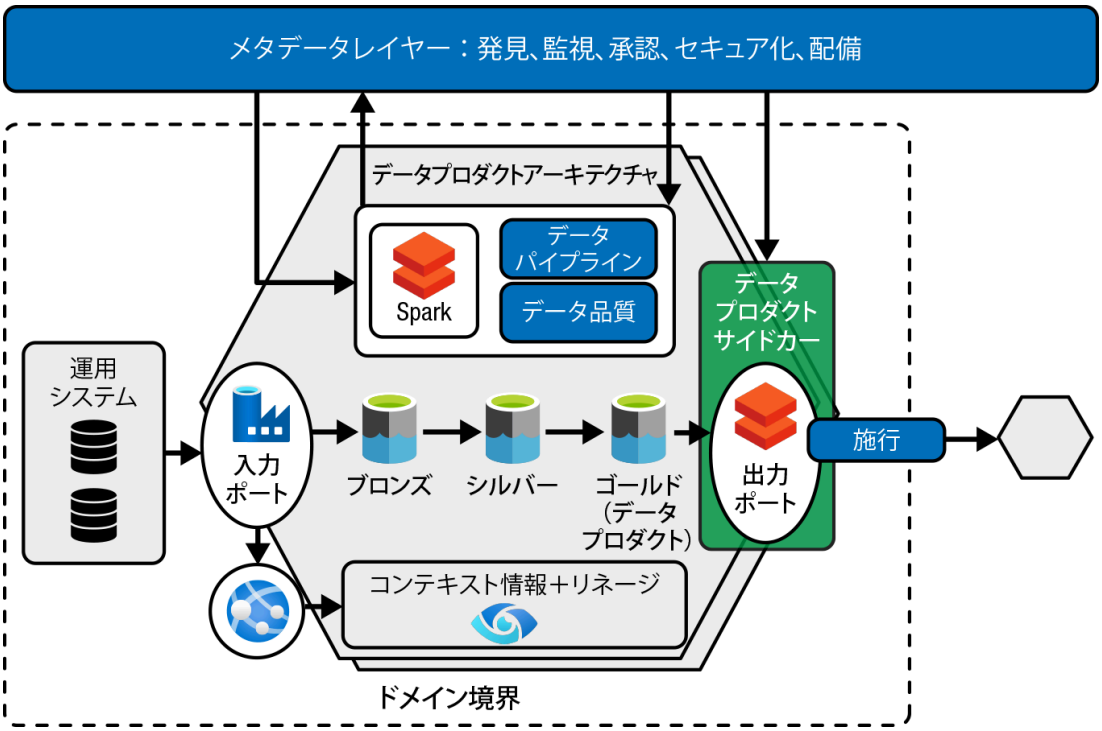

図8-7　データプロダクトアーキテクチャ更新版

図8-6では、各セキュリティコンポーネントが重要な役割を果たし、そのほかのコンポーネントや基盤となるデータプロダクトアーキテクチャと密接に連携することが想定されています。アーキテクチャの2つの部分がどのようにつながっているかを見てみましょう。

- 図8-6に示すように、データ契約管理アプリケーションは、どのデータをどのような目的で利用することが許可されるかということについて、データプロバイダーとデータコンシューマ間の正式な合意をすべて保持しています。このアーキテクチャでは、データ契約管理アプリケーションがPDPおよびPAPとして機能します。
- メタデータ駆動型のインジェストフレームワーク（図8-6）は、ETLプロセスを管理します。このフレームワークは、データの抽出、結合、変換、ロードに必要となる依存関係や順序を管理します。このアーキテクチャでは、このフレームワークがPIPの役割を果たし、どのようなデータプロダクトが利用可能かを共有します。
- データプロダクトオブザザーバビリティストア（図8-6）は、このアーキテクチャ内のすべてのデータプロダクトの稼働状況と状態を把握しています。このストアは、さらに多くのコンテキストを提供することで、PIPの役割を果たします。同時に、SLAの入力となる情報を提供します。
- データプロダクトサイドカー（図8-7）は、PEPなどのセキュリティ機能を施行するアクセス層です。アーキテクチャ上部のPDPとPAPから情報を受け

取ります。

- 図8-6に示すデータカタログには、追加のコンテキスト情報（ビジネス用語、リネージ、ラベル、分類などのメタデータ）が格納されます。データプロダクトアーキテクチャにおいて、データカタログはその役割を果たすために、データをスキャンしてメタデータを収集します。セキュリティアーキテクチャでは、データカタログは、データに関する情報を提供するPIPの役割を果たします。
- データパイプライン（図8-7）は、サービスを備えたオーケストレーションコンポーネントです。メタデータ駆動型インジェストフレームワークで記述されたシーケンスで、データをエンドツーエンドで処理します。DCAコンポーネントとGreat Expectationsのようなデータ品質フレームワークを使用して、どのような変更を許容するかを判断します。例えば、どのデータプロダクトもデータ消費の対象になっていない場合には、破壊的な変更を許可するようなこともできます。
- データ施行コンポーネント（図8-7）は、データへのアクセスとクエリを許可します。誰がデータにアクセスしたかについての情報もログに記録します。RBAC、ABAC、ACLを活用する場合は、通常SSOトークンを使用します。このSSOトークンはログファイルの中に記録されます。この種の監査データにより、分析についての分析を実行できます。つまり、どのプロダクトが本当に人気があり、誰に、どのように使用されているかを判断できます。このような情報により、データ資産を優先順位付けたり、ランク付けたりできます。

セキュリティコンポーネントは互いに密接に関連しています。このため、次の項では、データの導入（インジェスト）と消費のプロセスを説明します。それぞれのステップを眺めながら、コンポーネントを参照して、アーキテクチャにおけるそれぞれの役割を説明します。次の項が終わるころには、これらのコンポーネントがどのように連携して動作しているかを十分に理解していることでしょう。

8.2.8　典型的なセキュリティプロセスの流れ

データ提供の最初のステップは、データの導入とメタデータ情報の提供です。このステップでは、新しいデータセットがデータカタログに登録され、メタデータ駆動型インジェストフレームワークを使ってパイプラインが設計されます。データがデータプロダクトアーキテクチャに移動すると、カタログがそのデータを分析し、スキャンします。このステップは、オーナーにとってもデー

タ説明の出発点となります。ビジネス用語を物理データに関連付けます。導入プロセスで、データとその目的も分類し、自動的にラベル付けするべきです。

このようなデータ導入プロセスは、データを自動分類する機械学習やプロファイリングシステムを活用することで高速化することができます[†4]。このようなシステムでは、社会保障番号、クレジットカード番号、顧客名、住所などを自動的に判別することができます。さらに多くのメタデータを提供すると、AIや機械学習モデルはより賢くなり、提案を行うことでプロセスを改善し、分類の信頼性を向上することができます。

[†4] Purviewの自動分類プロセスの例が、Microsoft Purviewのドキュメント（https://oreil.ly/7XvuF）に記載されています。

運用上のユースケースでも、セキュリティコンテキストを保持することは大切です。セキュリティコンテキストは、運用分析においても必要な情報だからです。機密ラベル、国、ドメインの範囲など、ローカルドメインのデータは、データの一部として登録したり、データ導入時に提供したりしなければなりません。このようなコンテキストをデータに付与しなければ、後々、よりきめ細やかなセキュリティルールを施行することが難しくなります。データが分類され、説明がなされた後に、データは認証され利用可能になります。

次のステップはデータ消費です。このステップは、データオーナーとデータユーザーの双方が、どのようなデータをどのような目的で利用するか、またフィルタリングの基準について合意することから始まります。この合意なしには、データの消費はできません。

> データ契約は、データユーザーがまだアクセス権を持っていない場合にのみ締結されます。もし、データユーザーが、すでに特定の目的のためにデータを参照することを許可されている場合は、自動的にアクセスが許可されるはずですので、合意の手続きを踏む必要はありません。

契約を結んだら、次のステップは正しい判断を行うための情報収集です。このステップは、どのような情報を使用するかにもよりますが、複数のサブステップが含まれるため、より複雑になります。

1. 消費側のPIPから属性が収集されます。PIPは、ユーザーやアプリケーション、部門、グループ、役割、目的、組織内での開始日、最後にサインオンに成功した日などの情報を提供します。これらの情報はすべて、以下の一連の作業での情報として使われます。これらの属性は、例えば複合API（ほかのAPIを順次呼び出すコンポーネント）を介して抽象化され、収集されます。
2. データそのものに関する情報が収集されます。分類、ラベル、ファイルやコンテナの場所、運用可能な状態、データが単体でアクセスされているか、ほかのデータセットと組み合わされているか、などです。例えば、Microsoft Purview を使用している場合、REST API（https://oreil.ly/xiCNr）を使用して、コンシューマが要求しているオブジェクトの詳細情報を取得します。
3. 図8-6にはありませんが、対象アプリケーションと消費ユースケースのメタデータについては、消費アプリケーションの評価や分類、本番稼働状況、実行時の詳細などが収集されます。例えば、消費アプリケーションが開発環境やテスト環境で実行されている場合、データの使用を制限することができます。
4. オプションとして、関連するメタデータストア（図8-6には図示せず）に、前回のデータベースアクセス時間、テレメトリーデータ、従業員データ、インフラストラクチャー情報（オンプレミスまたはクラウド）などの情報を問い合わせます[†5]。例えば、データアクセスワークフローから、従業員管理システムを呼び出して情報を取得することができます。従業員が最近

解雇されたという情報を得た場合、システムはアクセスを拒否することができます。

5. 収集された情報はすべて組み合わされ、ポリシーを適用するためにPDPに提供されます。

[†5] **テレメトリー**とは、遠隔地や物理的にアクセスできない場所で、測定値などのデータを収集し、受信装置に送信して監視できるようにする自動通信プロセスのことです。

ここで説明したプロセスは、多くのメタデータを利用して複雑な意思決定を行う、将来の高度なシナリオとしてとらえることができます。セキュリティアーキテクチャを設計し実装する初期段階では、意思決定ははるかに単純で現実的なものになります。例えば、ラベル、本番環境かテスト環境か、フィルタリング情報だけから始めることもできます。この作業を進めていくうちに、より複雑な意思決定を行えるように、より多くの情報を追加し、徐々に拡張していきます。次の段階では、例えば、安全でない環境を排除したり、ラベルとデータ利用分類を組み合わせて使ったりするかもしれません。さらに進んで、機械学習ベースのサービスを利用し、データオーナーやセキュリティ責任者のかわりに、モデルを訓練して推奨や判断を行わせるようにしても良いでしょう。

別の方法としては、データ資産への特定レベルのアクセス権を持つセキュリティグループを（各データオーナーごとに）作成し、それを権限ライフサイクル管理エンジンと共有する方法があります[†6]。このような機能は多くの場合IDPに含まれており、多段階の承認ワークフロー、有効期限設定、外部ユーザーに対する条件付きルールなどを管理します。権限エンジンは、複数のデータ資産のセキュリティグループをアクセスパッケージに統合しカタログにまとめ、コンシューマが発見して要求できるようにします。この方法では、クレデンシャルのパススルーを活用して消費契約を結んでいるため、アクセスポイントに関係なく、アクセス許可を効率的に管理できます。

[†6] Active Directoryでの権限管理については、Microsoftのドキュメント（https://oreil.ly/ocW8l）を参照してください。

ソリューション側では、状況は変わってきます。アーキテクチャがどのように設計されているかによって、施行方法は異なるものになります。なぜなら、さまざまなテクノロジーの選択肢と組み合わせが考えられるからです。例えば、PAP/PDPは、PythonとSQLを使って開発された自社製アプリケーションかもしれません。このようなアプリケーションには、意思決定を行ったり、セキュアビューやポリシーを適用したりするために、データ契約レコードとビジネスロジックが含まれています。また、商用ベンダーが提供するサービスを利用している場合もあるでしょう。PEPの設計もさまざまです。データプロダクトのアーキテクチャが、例えば、Databricks SQLやAzure SQLを使用している場合、`GRANT USAGE ON SCHEMA`や`CREATE SECURITY POLICY`ステートメントを生成する小さな配備フレームワークを開発し、実行時にデータベースの行レベルセキュリティ（RLS、row-level security）や列レベルセキュリティ（CLS、 column-level security）を施行するようにできます。基盤となるサービスは、通過するすべてのリクエストをインターセプトし、定義されたポリシーに従ってそれらを検証します。データプロダクトのアーキテクチャがHadoopベースのプラットフォームを使用している場合、PAPのポリシーを

Apache Rangerに変換することもできます。サードパーティのツールを使用する場合は、そのソリューション内でポリシーを管理する必要があります。

データ上にビューやセキュリティレイヤーを配備する代わりに、オープンソースライブラリやPrivitar（https://www.privitar.com）のようなサードパーティツールを使用して、新しいユースケースごとにデータを複製し、匿名化することもできます。典型的には、データプロダクトの（オリジナルと匿名化された）複数のバージョンを保持することになります。匿名化されたものは、すべてのコンシューマ向けの汎用的なものであっても、特定のコンシューマ用に作成されたものであってもかまいません。この方法の問題点は、ストレージの管理が増えることです。

これらの方法は、それぞれ単独で使うこともできますし、組み合わせることもできます。データ共有リポジトリと消費レイヤーを分離している限り、どのようなソリューションでも柔軟に使用することができます。すべてのデータに同じセキュリティモデルを一貫して適用しながら、さまざまな消費パターンをサポートできます。

ほかのシナリオをいくつか見てみましょう。

- コンシューマ固有の「ビュー」や「ポリシー」は、ワークフローに従って自動的に配備されます。契約に基づき、特定のデータを非表示、フィルタリング、マスク、スクランブルすることができます。この種の機能では、データプロダクトアーキテクチャがほかのコンポーネントと連携する必要があります。例えば、行レベルのセキュリティを実装する場合、ビューの `WHERE` 条件にセキュリティ述語を直接組み込むのが簡単です[†7]。
- サードパーティのソリューションを使用して、リアルタイムで施行されます。SSOで認証されたユーザーやアプリケーションがデータにアクセスしようとすると、クエリがインターセプトされ、判断が行われ、データが返されます（または返されません）。
- ある特定の目的（アドホックレポート、データ探索など）のために、特定のツールだけに有効期限付きでアクセスを許可できます。例えば、ラングリングツールに対しては、特定の状況でのみ、一定期間だけデータへのアクセスを許可するようにもできます。
- データを複製し、ある特定のプロジェクトやユースケースのためだけに前処理をすることができます。この処理の過程で、データをマスクしたり、隠したり、フィルタリングしたり、トークン化したり、暗号化したりする

ことができます。このシナリオは、非常に大きなデータセットの場合に適しています。

[†7] Azure Synapse Serverless SQLプールで行レベルのセキュリティを実装する方法に興味がある方は、Jovan Popovic氏のブログ（https://oreil.ly/Gisds）をご覧ください。

ポリシーが適用され、データへのアクセスが許可された後、データの旅は消費側で継続します。そこではアプリケーションとケイパビリティが登場します。コンシューマがデータプロバイダーになったときに、この項で説明したプロセスフローサイクルが終了し、再度すべてのステップが実行されることになります。

最初は、コンポーネントの数、メタデータの量、ステップの多さにうんざりすることでしょう。そのため、セキュリティアーキテクチャの構築はゆっくりと進めるようにしてください。以下のような点に注意します。

ドメイン境界内のセキュリティと、境界をまたぐセキュリティに注意します。
この2種類のセキュリティを注意する方法では、ドメイン間のデータアクセスは粗視化し、データプロダクトの契約によって処理します。例えば、ドメイン間では、リソースは、読み出し専用権限を持つセキュアなエンドポイントを介してアクセスされるようにします。次に、ドメイン内のセキュリティについては、一般的に、ユースケースやプロジェクトレベルでデータアクセスを制限するための別パターンがあります。このレベルのセキュリティは、一般的にきめ細かく、ドメイン自体で処理します。

無理をしないでください。
まず、主要なメタデータを収集し、分類を絞り込んで、消費パターンを1つか2つ作成することから始めます。徐々に進めながら、より高度な機能とメタデータでアーキテクチャを拡張していきます。最後に、さらに拡張して、完全にセルフサービスにします。

できるだけ自動化します。
データの導入と消費のプロセスをできるだけ簡単かつ自動化しましょう。最初は、プロセスを手作業で行い、メタデータをMicrosoft FormsやExcelに保存するのかもしれません。しかし、進めていくうちに、可能であれば何でも自動化するようにしてください。

認証とデータアクセスを標準化します。

データを広く利用できるように、また、データの民主化のプロセスを簡単にするために、セキュリティの取り組みを企業全体のデータ管理ワークフローと整合させます。

適切なツールを選択しましょう。

セキュリティアーキテクチャを設計するのは難しいため、実績のある既製のパターンを使用することを検討してください。

最初からガイダンスを用意してください。

データプロダクトを管理するための適切なガイダンスが提供されなければ、きめ細かなデータアクセスを実現することは難しくなります。

最後の点については、ビジネスケイパビリティが共有された場合に、どのようにオーナーシップを取り扱い、どのようにデータプロダクトを管理するかを検討することが重要です。どのようなガイダンスをチームに提供する必要があるでしょうか。この点については「2.3.2.4　共有ケイパビリティ」ですでに説明しました。しかし、このような場面に適用できる方法はほかにも存在します。まず、図8-8の上部にあるように、異なるデータオーナーに対して複数のデータプロダクトを個別に作成し、データを物理的に分割する方法です。この方法は通常、データオーナーシップと利用方法が粗視化されている場合にうまく機能します。つまり、データが関連付けられているオーナーが少数であり、コンシューマが要求するデータが1人のオーナーに対応付けられる場合です。

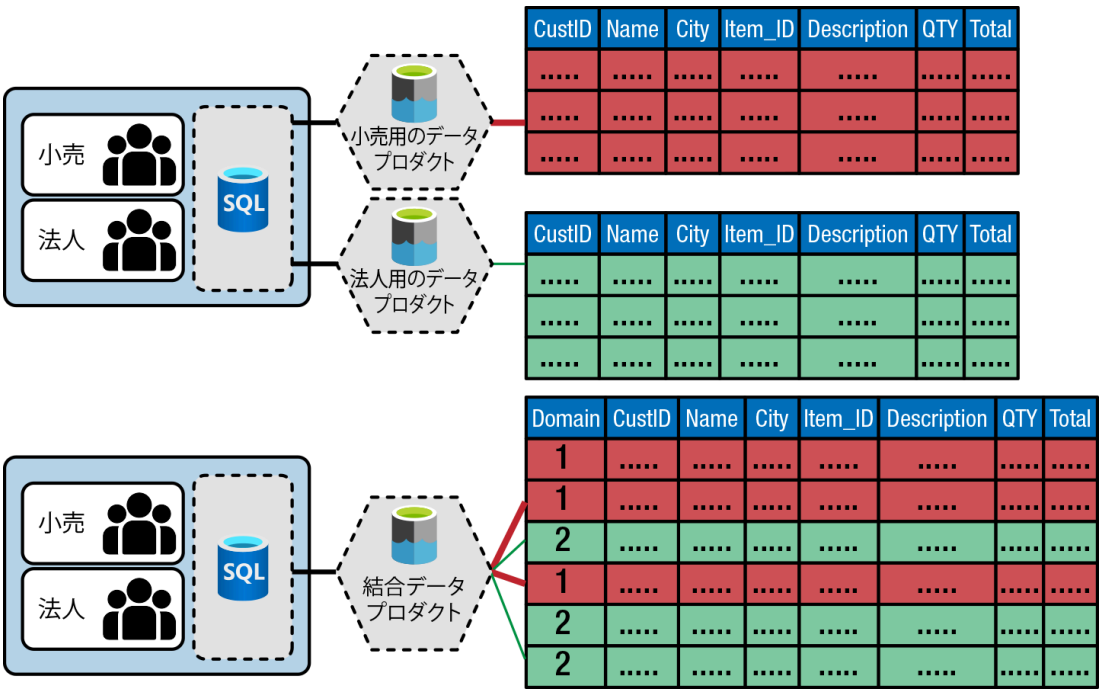

図8-8　共有されるデータオーナーシップに対応する方法

このほかに、図8-8の下部にあるように、データプロダクトの作成プロセスでセキュリティ用のメタデータをカプセル化する方法もあります。このメタデー

タは、セキュリティとカスタム表現に使用されます。カスタム表現では、一般的に、データの選択（動的な仮想ビュー）が必要となります。例えば、コンシューマがデータプロダクトを要求するとき、コンシューマが参照・使用することを許可されていないデータをフィルタリングするために、`WHERE`節が設定されます。

セキュリティのためのメタデータをカプセル化する方法は、データセキュリティがきめ細かい場合、つまりデータオーナーが多く、複雑なセキュリティの設定を管理しなければならない場合に非常に効果的です。このようなオーバーヘッドに対応するためには、データオーナーシップの委譲モデルを導入して、すべてのデータオーナーに対して承認を得なくても良いようにしましょう。例えば、コンシューマが1つのデータプロダクトを要求する場合に、そのデータプロダクトに20人のオーナーがいたとしても、1人のデータオーナーにのみ承認を求めれば良いようにします。

ここでの議論では、データプロダクトアーキテクチャのセキュリティに焦点を当ててきましたが、セキュリティはこれだけではありません。次の項では、APIとイベントベースのアーキテクチャにおいて、セキュリティを確保するための懸念事項について検討します。

8.2.9　APIベースアーキテクチャのセキュリティ

例えばSOA内のAPIをセキュアにすることは、通信がリアルタイムで行われるため単純ではありません。セキュリティは通常2つのレベルで行われます。APIレイヤーとAPIプロバイダーです。

セキュリティの最初のレベルは、APIゲートウェイ、エンタープライズサービスバス、サービスメッシュを使用するAPIレイヤーで行われます。図8-9に示したように、APIコンシューマは、まず、ある特定の認可サービスを呼び出して自らのIDを認証しなければなりません。認証に成功すると、IDトークンやアクセストークン（オプションで更新トークン）が提供されます。APIコンシューマは、そのトークンを使用することで、認可されたAPIを呼び出せます[†8]。API管理プラットフォームのAPIゲートウェイが、これらのリクエストをインターセプトし、アクセス権の範囲とトークンが有効かどうかを検証します。トークンを定期的に検証するために、APIゲートウェイは認可サーバーに直接問い合わせる場合があります。API管理プラットフォームに格納されるAPIポリシーは、データ契約アプリケーションから発行されなければなりません。APIポリ

シーはこのデータ契約アプリケーションから抽出されAPIセキュリティポリシーに変換されます。または、APIポリシー決定エンドポイントがデータ契約アプリケーションとして機能します。このモデルでは、APIゲートウェイは事実上PEPになります。

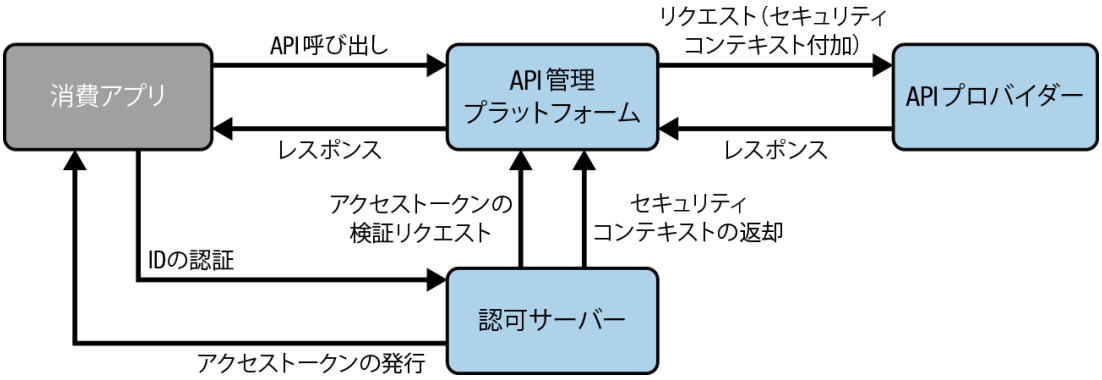

図8-9　認証に成功した後、コンシューマがどのようにAPI呼び出しを行うかを示した認証フロー（この設計における認可サーバーは、API管理プラットフォームの一部であっても、サードパーティサービスでも良い）

[†8] OAuth2.0による認証の仕組みについては、Apigeeのガイド（https://oreil.ly/Alm_M）をご覧ください。

セキュリティの2つ目のレベルは、データを提供する側で実施されます。このモデルでは、APIコンシューマとAPIゲートウェイから提供されたコンテキストを使用して、データを返すかどうか、どのデータを返すかを、APIプロバイダーが決定します。APIゲートウェイは、APIプロバイダーにコンテキスト（メタデータ）を追加して渡すことができます。例えば、ドメインに関する情報や、初回の認証時刻などです。API管理ソフトウェアプロバイダーの中には、ほかのサービスからコンテキストを受け取ったり取得したりするために、**マッピングテンプレート**（https://oreil.ly/kanWm）を利用しているものもあります。APIゲートウェイがこのような処理をサポートしていない場合、小さなマイクロサービスを構築して、軽量なプロキシとして機能させ、このようなコンテキストを提供することを検討してください。このモデルでは、APIプロバイダーがデータ契約アプリケーションをPDPとして使用し、データ契約アプリケーションを利用してコンシューマがアクセスできるかどうかを判断することもできます。また、ローカルコンテキストとビジネスルールを使用して判断してもかまいません。

APIゲートウェイとAPIプロバイダーを組み合わせて使用する場合、これまで説明してきた認証モデルとは別の方法を使うこともあります。IDプロバイダーがAPIゲートウェイから分離されずに、直接呼び出される場合もあります。API呼び出しやスコープによっては、ほかの認可エンドポイントから情報を取得することもあります。また、何種類かのアクセストークンを組み合わせることもできます。

API管理でのクロスドメインのセキュリティは簡単ではありません。ほかのドメインからのコンテキストが追加で必要となることが多いからです。あるシステム（例えば、注文管理システム）にアクセスした場合、実際のセキュリティ情報が別のシステム（例えば、顧客システム）に格納されているときに、要求された情報を取得することが許可されているかどうかを、そのシステムはどのように知るのでしょうか。このようなシナリオでは、いくつかの異なった方法を検討する必要があります。

- APIコンシューマは追加のコンテキストを「キャッシュ」し、APIを次に呼び出すときに、このキャッシュしたコンテキストを利用します。顧客管理システムと注文管理システムの例を使うと、APIコンシューマは、まず顧客管理システムを呼び出し、そこから代表者リストを受け取ります。次の呼び出しでは、注文管理システムからAPIを使用してデータを取得します。代表者リストは、このAPIを呼び出すための追加コンテキストとして送信されます。このモデルは良い方法ですが、すべてのドメインが同じ信頼境界内で動作する場合にのみ機能します。
- APIによっては、コンテキストを用意するために別の呼び出しが必要になることを、APIゲートウェイが知っている場合があります。例えば、Apigeeは、これを**ServiceCalloutポリシー**（https://oreil.ly/Myvvm）と呼んでいます。APIゲートウェイは、ほかのドメインを呼び出してコンテキストを収集し、いくつかの軽量のオーケストレーションを実行します。一般的に、この方法は、クライアント側で処理が行えるので、前の方法よりも安全であると言えます。この方法を使用するかどうかは、消費ドメインが完全に信頼されているかどうかにもよります。この方法の利点は、APIゲートウェ

イがコンテキストをキャッシュできることです。そのため、もう一度呼び出しを行ったとしても、コンテキストを再び取得する必要がありません。欠点は、セキュリティ属性が変更されたときに、APIゲートウェイが正しくないコンテキストを提供してしまう場合があることです。したがって、変化の激しい環境では、APIを呼び出すたびに、コンテキストを更新する方が良いでしょう。普通、ドメインは、どのような方法が個々のユースケースに最適なのかを理解しているはずです。

- 追加のコンテキストを取得するために、APIコンシューマからの識別トークンをドメインが使用します。このモデルでは、APIゲートウェイが仲介役になります。この方法では、すべての関連するドメインが同じIDプロバイダーを使用しなければなりません。このモデルは、トークンがそれほど頻繁に更新されない場合にのみうまく動作します。したがって、APIを呼び出すたびに、新しいトークンが渡されるようなモデルではうまくいきません。
- API呼び出しを受け取った後、ドメインが直接ほかのドメインを呼び出して必要なコンテキストを取得します。この方法の短所として、API呼び出しがピンポンのように行ったり来たりしてしまう場合があることです。この方法は、決して間違ってはいるわけではありません、ただし、APIゲートウェイを利用するよりも良いとは言えません。

セキュリティモデルをどうするかは、どのようなテクノロジーを使うか、どの程度の信頼を置くかによって変わってきます。大企業では、専用のセキュリティ製品やコンポーネントをアーキテクチャ内に配備することで、セキュリティレイヤーをAPIアーキテクチャから分離している場合も見受けられます。

また、遅延もセキュリティモデルに影響を与える場合があります。APIリクエストを短時間で処理しなければならない場合、ネットワーク上のホップごとに待ち時間が発生するため、セキュリティレイヤーを追加すると問題が起きるかもしれません。ドメインを直接呼び出すしか方法がないかもしれません。ただし、一般的に、これはベストプラクティスというよりも、例外的なケースだと考えています。

APIセキュリティにおいて、よく問題となるのは、統合ビューが必要とされ、さまざまなデータや統合ロジックなどをまとめなければならない場合です。例えば、ある形式のデータを継続的に提供する場合に、さまざまなバックエンドサービスへの複数の呼び出しが必要になることがあります。このような状況では、複数のサービスを組み合わせて、新しいサービスとして公開する複合サービスを利用します。このような複合サービスを利用すれば、コンシューマとプ

ロバイダー間の頻繁なやり取りを行わなくてすむようになり、性能への悪影響を避けることができます。こういったサービスでは、データガバナンスを厳密に遵守するようにしてください。

このような状況での第一のルールは、すべてのローカルデータとセキュリティルールは、元のプロバイダーが所有しつづけるということです。データとルールはアグリゲータによって変更されてはなりません。第二のルールは、アグリゲーションサービスは、新しく作成されたデータも含めて、すべての包括的なルールのオーナーシップを持つというものです[†9]。例えば、データのある特定の組み合わせについて、その消費を許可しないという包括的なルールが考えられます。このような包括的なルールは、アグリゲーションサービス自身によってのみ作成・管理されます。なぜなら、データの組み合わせが保存されるのはアグリゲーションサービスだけだからです。最後のルールは、（アグリゲーション）サービスプロバイダーが認可のために必要とする、あらゆるコンテキストを提供する責任があるのは、データコンシューマということです。包括的なルールは複雑ですので、多くのコンテキストが必要となる場合があります。

[†9] あるいは、すべてのポリシーと属性を保持する中央セキュリティメタデータストアに、包括的なルールを格納することもできます。この場合、アグリゲーションサービスは、ポリシー管理点（PAP）ではなくなります。

8.2.10　イベント駆動型アーキテクチャのセキュリティ

ストリーミングアーキテクチャやイベント駆動型アーキテクチャにおいては、ポリシーベースのアクセス制御をすぐに利用できるようなセキュリティフレームワークが現在存在しません。このため、複雑なものになります。 例えば、KafkaはRBAC（https://oreil.ly/v_iKy）にしか対応しておらず、属性の組み合わせによるポリシーベースのメッセージフィルタリングは提供していません。そのため、きめ細かなABACセキュリティモデルが必要な場合は、コンポーネントを追加して補完するか、自分で設計する必要があります。

1つの方法は、ポリシー施行レイヤーを設計する方法です。このポリシー施行レイヤーは、マイクロサービスを使用してイベントを読み出して、データ契約アプリケーションやポリシーエンジンから指示を受け取り適用します。出力されるイベントは、コンシューマ専用の新しいトピックに格納されます。イベン

ト駆動型アーキテクチャでは、イベントが入力されたときには、まず内部トピックに格納されます。アプリケーションの状態を長く保持したい場合は、これらのトピックをコンパクト化する場合もあります。次のステップでは、すべてのセキュリティポリシーと関連するメタデータを、イベントストリーミングプラットフォームに取り込みます。最後のステップは、ポリシーベースのメッセージフィルタリングフレームワークを設計することです。このフレームワークでは、マイクロサービスが受信データを読み出し、ポリシーからのデータと結合し、データをフィルタリングして、コンシューマが参照できるデータのみをコンシューマ専用のトピックに提供します。このフィルタリングフレームワークは、ポリシーを決定するのに必要であれば、ほかのコンテキストからデータを結合する場合もあります。例えば、データプロダクトアーキテクチャから、特定の金融取引の顧客担当者を取得します。

これらの例からわかることは、多くの選択肢があり、また、どの選択肢を使うのかはコンテキストに左右されるということです。セキュリティを設計し、組み込むには、どのコンポーネントを使用し、アーキテクチャ全体にどのように適用するかについて深く考える必要があります。

8.3　まとめ

データガバナンスは、適切なデータセキュリティなしには成り立ちません。その逆も同様です。この2つの領域は密接に絡み合っています。

適切なデータガバナンスは、データを活用する上で、重要なポイントになります。法規制を遵守するためには、オーナーシップを定義し、リネージ、分類、目的、説明などに関する標準を策定することが重要です。これらの作業では、組織内のすべてのアプリケーションと一意な（ゴールデン）ソースを明らかにすることも重要です。データガバナンスを大規模化するには、関連する役割とその責任の所在を明らかにし、それらを適切に割り当てる必要があります。まずは小さく始めて、短期間で成果を上げるよう努めましょう。例えば、小さなユースケースから始めるようにします。各ユースケースにはデータプロダクトが必要です。各データプロダクトについて、データレベルやアプリケーションレベルでオーナーシップが明確になっていることを確認します。最初のデータプロダクトを開発しながら、データプラットフォームチームがデータカタログを作成し、データとその使用方法に透明性を与えます。さらに、メタデータを最初から収集します。基盤を整えたところで、徐々にDataOpsの手法を採用し、その手法を本格化させます。

データガバナンスを導入する作業の大部分は、組織を変革することです。カルチャーは大きな障害にもなれば、起爆剤にもなりえるからです。変革への前向きな姿勢や意欲がなければ、せっかくの取り組みも失敗に終わるでしょう。これを克服するには、ワクワク感、活力、そして勢いを生み出す必要があります。筆者は長年にわたって、変革には、コミュニケーションと透明性、そしてデータサポーター（模範となるリーダー）の支持を得ることが重要だと学んできました。

データセキュリティについては、データリクエスト処理をサポートする、エンドツーエンドのフレームワークを構築することが重要です。データプロダクトの流通と消費において、このフレームワークがセキュリティモデル強化のスタート地点となります。アーキテクチャ全体の中で、ここが非常に重要な部分になります。そして、もっと多くのメタデータ、分類、ラベル、属性などを追加して、拡張していきましょう。さらに規模を拡大するために、機械学習でインテリジェント化するのも良いでしょう。

次の章では、メタデータ管理、マスターデータ管理、データを価値に変えることに焦点を当てます。